

A Miser's Guide to

HARDENING ACTIVE DIRECTORY

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Intro Section - 4 min

This slide: <1 min

Hello and thanks for coming to this talk. I'll be giving a Miser's Guide to Hardening Active Directory. If you're here for something else you're in the wrong room.

\> INVOKE-WHOAMI

```
Name = Tyler Jacobs
Alias = Poolmanjim, ActiveDirectoryKC
Job = @{
    Title = Principal Security Engineer - Identity
    Organization = Type.UndisclosedHealthCare
    Experience = (Get-Random -Min 15 -Max 20)
}
Contact Info = @{
    Discord = @poolmanjim
    Website = activedirectorykc.net
    github = github.com/ActiveDirectoryKC
    Reddit = u/poolmanjim
}
Interests = Identity, Homelab, TTRPGs, Gaming
```



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

This Slide: 2 min

Who am I?

I'm Tyler. Otherwise known as Poolmanjim in most of my online circles. I am from the KCK area so this is my hometown con!

I have been doing IT since I got the chance and been focused on identity for a good chunk of that now.

I work for a large healthcare organization as effectively the Principal Engineer for Identity. I'm not naming them here because I don't want to be openly linked to them, but it isn't a secret.

I'm very much an on-prem guy still who embraces the cloud but wants to use it sensibly. I'm also super sketchy of AI. (slide)

I'm one of the mods for r/ActiveDirectory and enjoy participating there when time allows. I encourage you to check it out, but especially check out the wiki there because we have tons of links and resources around identity and AD.

My contact details on are screen, but they'll be at the end too.

I have a family, a wife and two young boys. That's fun and for fun I like tinkering with my lab,

playing games, especially D&D, but I'm not picky about the game. No I probably haven't played the game your thinking of. :)

This is my first conference talk and I got a C+ in Public Speaking so you're all in for a treat! And I have ADHD so you're in for a ride!

WHAT'S THIS ALL ABOUT?

Active Directory Is not dead!

Security isn't free.

We have to start somewhere.

Not overcomplicated.



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 2 min

Show of hands: Who in here expects AD to not be a thing anymore in 10 years?

[RESPOND]

[slide]

Most organizations that have Active Directory aren't expecting to get rid of it any time soon, so we have to support it. [slide]

A challenge we experience is that maintaining and securing a system both have costs and they may be competing. [slide]

It exists and we have to secure it, but security isn't free. So what do we do. [slide]

The whole motto of this talk is simple: "The hardest part of any important task is getting started on it in the first place. ."

The plan is to give some rough steps, not the details, but places to start and actions to take that will get you started making your AD better.

The goal is to give you mostly affordable, or outright free options, that will keep the gold in Scrooge's vault. [slide]

Action matters. Rather than focusing on projects that will languish for years, the elements I'll cover are pointed and actionable to get real gains in the real world.

DISCLAIMERS / WHAT IS THIS NOT?

- TOOLS MAY TRIP EDR/SIEM/AV
- MOST TOOLS FREE – SOME AREN'T
 - I DON'T WORK FOR THEM
- FREE TOOLS OFTEN REQUIRE EMAILS*
- OPINIONS ARE MINE
- NOT AN EXHAUSTIVE LIST



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

This Slide: 1 min

Disclaimers first.

[slide]

The tools, scripts, and applications I mention are tools that tend to overlap with redteamers/bad guys. There is a chance they'll trip EDR and monitoring. Make sure you coordinate with your SOC

[slide]

I don't work for any of these tools or vendors. Most of the tools are free, some aren't as free. Point is. They're not my work just things that have stood out to me over the years.

[slide]

Tools may ask for emails. You can get around that using the temp email tools. It's up to you. If i can I provide email-free links.

[slide]

Any opinions here are mine. My employer had nothing to do with this so blame me not them.

[slide]

This is not an exhaustive list. I could spend weeks talking about AD Hardening. I have 50 minutes. I have lots of notes and bonus slides in the deck to help more.



THE GHOST OF BACKUPS ARE EXPENSIVE

Business Resilience
& BCDR

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Section Time: 8 minutes

This slide: < 1 minute

Let's see hands: Who here has backups?

Okay, who here has tested and validated a full forest recovery in the last year?

Yeah get on that.

BCDR is kind of boring. That's probably the reason it doesn't get a lot of love at talks.

You get backups. If you're smart you test backups. You forget you have backups. Maybe your org does yearly tabletops.

They're not shiny or cool. But they are essential. This section may be my most important for that reason alone!

WHY ARE BACKUPS IMPORTANT?

Go from "Oh S***" to "Okay?"



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: <1 min

Why are backups important?

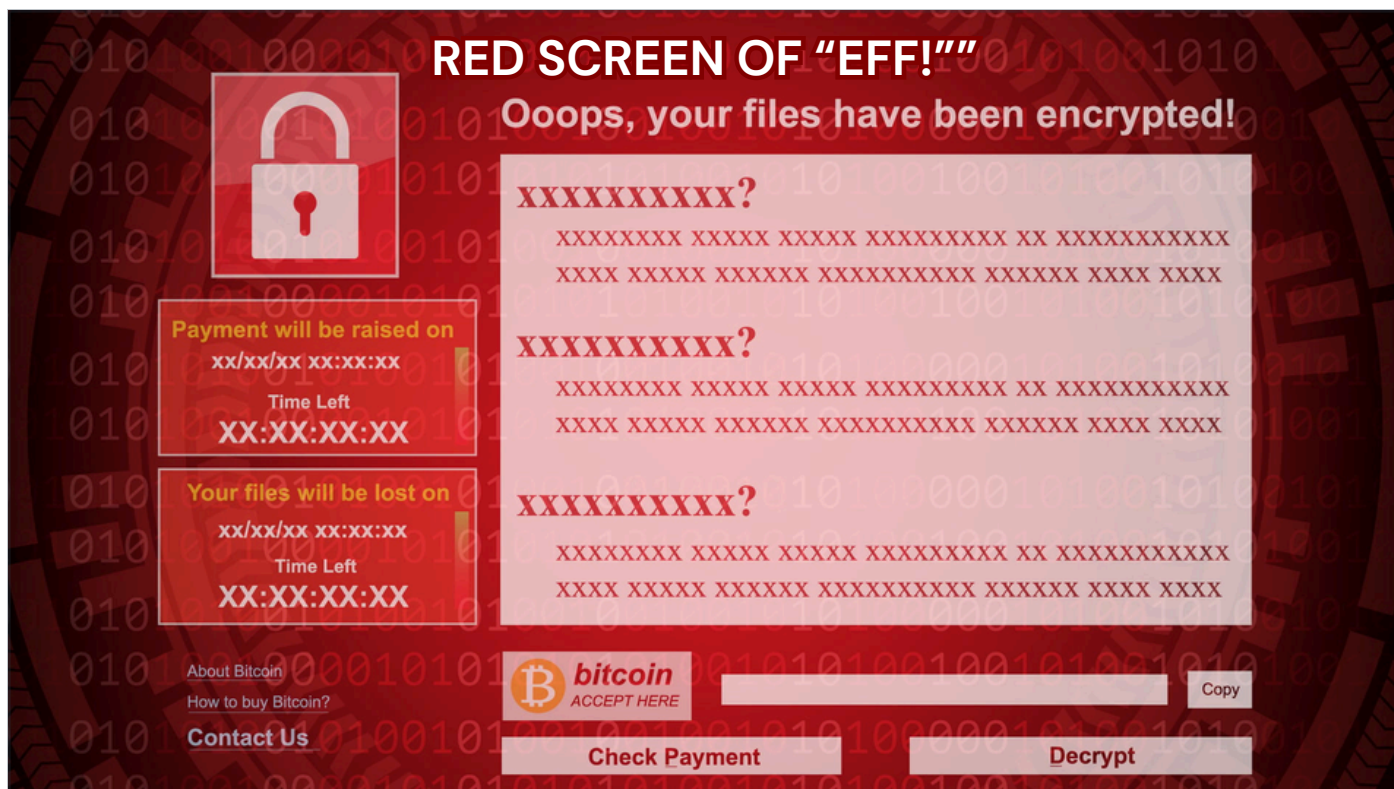
[slide]

They get you from "Oh crap!" to "Okay".

[slide]

We often think of BCDR like this. A building burns down, a comet hits the building, etc. In fact most organizations are fairly well prepared for those contingencies. Insurance companies are prepared for those.

[slide]



Slide Time: 1 min

What happens if you log in and see this screen on your systems? Worse what if you see it on your domain controllers?

Where do you go from there?

I can tell you that your EDR may not stop this from happening.

There are not any guarantees on this red screen. It's not like the malware guys sign up for the BBB.

Think about this: If the entire identity system is down, what can you do? No email. No teams. Phones may not work. What do you do?

You have to have options.

BAD NEWS... :(

GOOD BACKUPS COST \$\$\$

Are they worth it?

YES!

- **Support**
- **Insurance**
- **Features**

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 2 min

When talking about options, there is some bad news. Good backups cost. Backups have to be good and they have to be fast, which means they're going to cost.

[slide]

Is the cost of your entire IT budget for that year worth it?

[slide]

100%. Yes. Absolutely!

The main reason for this is the first bullet.

SUPPORT!

When you're down, your job is on the line, everyone's yelling, etc. it is crucial to be able to offload some of that stress. Having a vendor to call to help you will make the whole process go faster!

There are other benefits, you have the insurance that someone else did some of the work and you get features which most free tools don't have, but support is your win with BCDR.

The tool is important. You want your BCDR tool to be usable, but that is actually not the most important reason to buy a solution.

Don't get me wrong, there are workable cheaper/free options. I argue this is the hill worth dying on.



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 1 minute

When thinking about solutions remember that VM snapshots are not backups. They're just not!

There are too many little gotcha's buried in with VM snapshots being *the* backup. That doesn't mean they can't augment the backup which some tools do.

Personally, I'm dubious of any solution that claims snapshots are their core component so keep that in mind.

References....

Veeam on snapshots not being backups: <https://www.veeam.com/blog/why-snapshots-alone-are-not-backups.html>

Veeam on AD backup best practices: <https://www.veeam.com/blog/backing-up-domain-controller-best-practices-for-ad-protection.html>

Semperis ADFR product page: <https://www.semperis.com/active-directory-forest-recovery/>

Semperis on ransomware dormancy and reinfection risk:
<https://www.semperis.com/semperis-faq/>

- Most backup solutions are either strictly file/block-based backup solutions or they are snapshot-b

ased.

- File/block-based copy files/blocks

- Snapshot based tend to work at the Hypervisor layer.

- File-only backups aren't normally AD-aware and can cause issues if they aren't. Same for block

- Snapshot-based are capturing the underlying OS.

- Bare Metal Recovery and System State can restore AD, but are effectively copies of the OS.

FINDING A GOOD SOLUTION

Business Requirements

- Business Tolerance?
- What are you protecting against?

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 3 min

We need a target; some goals.

What is the business need? Too many orgs go into BCDR forgetting that they need to know how far back to keep backups or what a reasonable amount of downtime looks like.

Execs love to say "Zero downtime" which is a great thing to say in the mirror. It's not realistic when thinking of BCDR.

[slide]

What are we protecting against? This focuses on what events and impacts are being considered.

Flooding? Fire? Malware?

But don't forget the human and technical elements. People make mistakes. Hard drives go bad. Ransomware gives you the red screen of "eff".

[slide]

Thinking of technical.

The solution has to be able to restore, specifically in this case it has to be able to restore AD safely and reliably.

AD is kind of a snowflake in how it likes to be restored, so the products need to actually be able to handle those quirks. Were not just file servers over here!

If you can't restore your target, what's the point?

[slide]

What does the security model of the solution look like? Is it encrypted at rest? If backups are replicated are they encrypted in transit? Do they have an RBAC model?

[slide]

Support. I've mentioned that before. It has to be supportable by the vendor.

[slide]

Resilience is a big part of BCDR. What if the malware goes after my backups? Does my solution, not just the product but my solution, have planned resiliency?

Does my BCDR depend on AD to restore AD, because that aint going to work?

FINDING A GOOD SOLUTION

Business Requirements

- Business Tolerance?
- What are you protecting against?

Technical Musts

Can it restore? AD?



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 3 min

We need a target; some goals.

What is the business need? Too many orgs go into BCDR forgetting that they need to know how far back to keep backups or what a reasonable amount of downtime looks like.

Execs love to say "Zero downtime" which is a great thing to say in the mirror. It's not realistic when thinking of BCDR.

[slide]

What are we protecting against? This focuses on what events and impacts are being considered.

Flooding? Fire? Malware?

But don't forget the human and technical elements. People make mistakes. Hard drives go bad. Ransomware gives you the red screen of "eff".

[slide]

Thinking of technical.

The solution has to be able to restore, specifically in this case it has to be able to restore AD safely and reliably.

AD is kind of a snowflake in how it likes to be restored, so the products need to actually be able to handle those quirks. Were not just file servers over here!

If you can't restore your target, what's the point?

[slide]

What does the security model of the solution look like? Is it encrypted at rest? If backups are replicated are they encrypted in transit? Do they have an RBAC model?

[slide]

Support. I've mentioned that before. It has to be supportable by the vendor.

[slide]

Resilience is a big part of BCDR. What if the malware goes after my backups? Does my solution, not just the product but my solution, have planned resiliency?

Does my BCDR depend on AD to restore AD, because that aint going to work?

FINDING A GOOD SOLUTION

Business Requirements

- Business Tolerance?
- What are you protecting against?

Technical Musts

Can it restore? AD?

Can it be secured?



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 3 min

We need a target; some goals.

What is the business need? Too many orgs go into BCDR forgetting that they need to know how far back to keep backups or what a reasonable amount of downtime looks like.

Execs love to say "Zero downtime" which is a great thing to say in the mirror. It's not realistic when thinking of BCDR.

[slide]

What are we protecting against? This focuses on what events and impacts are being considered.

Flooding? Fire? Malware?

But don't forget the human and technical elements. People make mistakes. Hard drives go bad. Ransomware gives you the red screen of "eff".

[slide]

Thinking of technical.

The solution has to be able to restore, specifically in this case it has to be able to restore AD safely and reliably.

AD is kind of a snowflake in how it likes to be restored, so the products need to actually be able to handle those quirks. Were not just file servers over here!

If you can't restore your target, what's the point?

[slide]

What does the security model of the solution look like? Is it encrypted at rest? If backups are replicated are they encrypted in transit? Do they have an RBAC model?

[slide]

Support. I've mentioned that before. It has to be supportable by the vendor.

[slide]

Resilience is a big part of BCDR. What if the malware goes after my backups? Does my solution, not just the product but my solution, have planned resiliency?

Does my BCDR depend on AD to restore AD, because that aint going to work?

FINDING A GOOD SOLUTION

Business Requirements

- Business Tolerance?
- What are you protecting against?

Technical Musts

Can it restore? AD?

Can it be secured?

Is it supported?



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 3 min

We need a target; some goals.

What is the business need? Too many orgs go into BCDR forgetting that they need to know how far back to keep backups or what a reasonable amount of downtime looks like.

Execs love to say "Zero downtime" which is a great thing to say in the mirror. It's not realistic when thinking of BCDR.

[slide]

What are we protecting against? This focuses on what events and impacts are being considered.

Flooding? Fire? Malware?

But don't forget the human and technical elements. People make mistakes. Hard drives go bad. Ransomware gives you the red screen of "eff".

[slide]

Thinking of technical.

The solution has to be able to restore, specifically in this case it has to be able to restore AD safely and reliably.

AD is kind of a snowflake in how it likes to be restored, so the products need to actually be able to handle those quirks. Were not just file servers over here!

If you can't restore your target, what's the point?

[slide]

What does the security model of the solution look like? Is it encrypted at rest? If backups are replicated are they encrypted in transit? Do they have an RBAC model?

[slide]

Support. I've mentioned that before. It has to be supportable by the vendor.

[slide]

Resilience is a big part of BCDR. What if the malware goes after my backups? Does my solution, not just the product but my solution, have planned resiliency?

Does my BCDR depend on AD to restore AD, because that aint going to work?

FINDING A GOOD SOLUTION

Business Requirements

- Business Tolerance?
- What are you protecting against?

Technical Musts

Can it restore? AD?

Can it be secured?

Is it supported?

Is it resilient?



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 3 min

We need a target; some goals.

What is the business need? Too many orgs go into BCDR forgetting that they need to know how far back to keep backups or what a reasonable amount of downtime looks like.

Execs love to say "Zero downtime" which is a great thing to say in the mirror. It's not realistic when thinking of BCDR.

[slide]

What are we protecting against? This focuses on what events and impacts are being considered.

Flooding? Fire? Malware?

But don't forget the human and technical elements. People make mistakes. Hard drives go bad. Ransomware gives you the red screen of "eff".

[slide]

Thinking of technical.

The solution has to be able to restore, specifically in this case it has to be able to restore AD safely and reliably.

AD is kind of a snowflake in how it likes to be restored, so the products need to actually be able to handle those quirks. Were not just file servers over here!

If you can't restore your target, what's the point?

[slide]

What does the security model of the solution look like? Is it encrypted at rest? If backups are replicated are they encrypted in transit? Do they have an RBAC model?

[slide]

Support. I've mentioned that before. It has to be supportable by the vendor.

[slide]

Resilience is a big part of BCDR. What if the malware goes after my backups? Does my solution, not just the product but my solution, have planned resiliency?

Does my BCDR depend on AD to restore AD, because that aint going to work?

SOME OTHER THOUGHTS ON BCDR

01

3 - 2 - 1 + 1 Rule

3x Copies of the data

2x Different Media Types

1x Copy Offsite

1x Copy Immutable/Write-Only

02

Protect Your Backups

Access Controls + Storage Restrictions

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 1 minutes

This slide is really about the one item. There's more, but it is for the notes.

[slide]

3-2-1 rule is the standard.

You need 3 copies of the data you're backing up.

You need those copies to live on at least 2 media types. I consider an on-prem type and cloud as acceptable here.

At least one copy should be stored offsite. Traditionally this meant in caves or bunkers. Now it is interesting because with cloud integration, what if your offsite is an S3, Glacier or Azure Storage location? Those need to be airgapped somehow or you need actual off site because of connectivity.

The newer addition to this rule is the +1 to say one copy should be immutable/write-only.

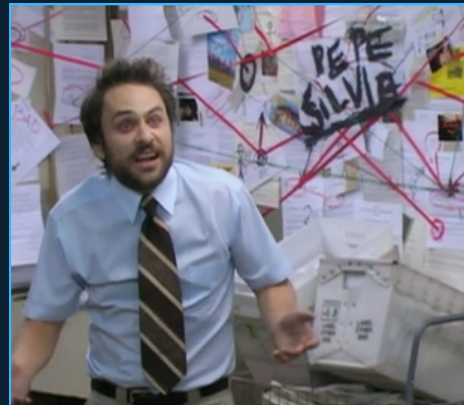
[slide]

You want to make sure your backups are protected. I mentioned encrypted and RBAC controls

but you should make sure the backups are treated as securely as the system they backed up. Make sure no one can just copy your backups and walk out. At least with AD you have to remember the backups are a copy of AD, including passwords and secrets.

REAL SOLUTIONS = A PLAN

Get an Enterprise Solution...



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 4 minutes

#1 recommendation: Get an Enterprise solution

What if we don't have the budget? Well there is some hope.

[slide]

Windows Server Backup. I know it isn't the best. Heck I wouldn't even call it good. But it is something you already have and it doesn't cost any extra. You can get BMR or System state backups with it pretty easy. It's also supported by Microsoft. They still talk about it in BCDR engagements, trust me.

Another option is Azure Backups. If you have an IaaS DC running in the cloud, Azure Backup can do the work. The big thing here is when on-prem is compromised the cloud-side often is too because of all the connections. Also, Azure security is about as bad as AD in many places so you may not have the access controls here you think. Nonetheless, it works.

By the way, most NAS solutions even off the shelf ones, tend to have Write-Only or Immutible modes that would account for immutable backups. The downside is the security. Immutible means squat if you have root access to the volumes. So that will have to be hardened for that to matter.

[slide]

IFM is "Install From Media". This is a feature of AD that allows you pre-seed the AD database to new domain controllers to reduce replication time. This file includes the NTDS.DIT, the database, the SYSVOL, and a few registry items.

The folks at DSInternals figured out a way to take the IFM data and generate a recovery script that will rebuild a DC with nothing shared. Fresh build on a new system with the correct domain, SID, etc. It's pretty cool.

Fun fact: Any enterprise tool that has a "clean os" option or similar, is likely using this behind the scenes.

The IFMs are not encrypted and really are just a blind copy of the AD database, secure them accordingly.

Together those can restore a DC. Its, very neat.

[slide]

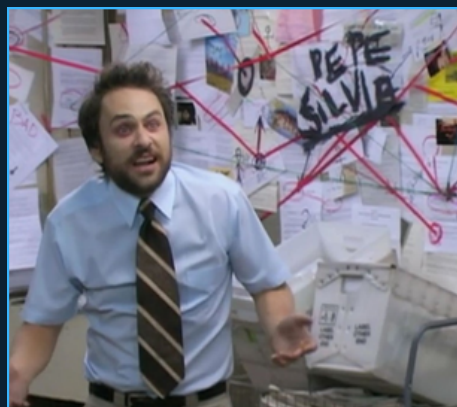
To that end I'm working on a collection scripts and stuff to smooth over the IFM + DSInternals process to create a backup solution gives some more flexibility. Keep an eye on my github for that.

REAL SOLUTIONS = A PLAN

Get an Enterprise Solution...

Windows Server Backup

Azure Backups



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 4 minutes

#1 recommendation: Get an Enterprise solution

What if we don't have the budget? Well there is some hope.

[slide]

Windows Server Backup. I know it isn't the best. Heck I wouldn't even call it good. But it is something you already have and it doesn't cost any extra. You can get BMR or System state backups with it pretty easy. It's also supported by Microsoft. They still talk about it in BCDR engagements, trust me.

Another option is Azure Backups. If you have an IaaS DC running in the cloud, Azure Backup can do the work. The big thing here is when on-prem is compromised the cloud-side often is too because of all the connections. Also, Azure security is about as bad as AD in many places so you may not have the access controls here you think. Nonetheless, it works.

By the way, most NAS solutions even off the shelf ones, tend to have Write-Only or Immutible modes that would account for immutable backups. The downside is the security. Immutible means squat if you have root access to the volumes. So that will have to be hardened for that to matter.

[slide]

IFM is "Install From Media". This is a feature of AD that allows you pre-seed the AD database to new domain controllers to reduce replication time. This file includes the NTDS.DIT, the database, the SYSVOL, and a few registry items.

The folks at DSInternals figured out a way to take the IFM data and generate a recovery script that will rebuild a DC with nothing shared. Fresh build on a new system with the correct domain, SID, etc. It's pretty cool.

Fun fact: Any enterprise tool that has a "clean os" option or similar, is likely using this behind the scenes.

The IFMs are not encrypted and really are just a blind copy of the AD database, secure them accordingly.

Together those can restore a DC. Its, very neat.

[slide]

To that end I'm working on a collection scripts and stuff to smooth over the IFM + DSInternals process to create a backup solution gives some more flexibility. Keep an eye on my github for that.

REAL SOLUTIONS = A PLAN

Get an Enterprise Solution...

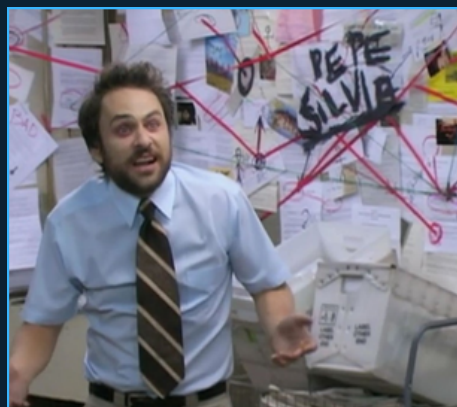
Windows Server Backup

Azure Backups

IFM + DSInternals

Coming Soon...

Not-So-Enterprise AD Backups



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 4 minutes

#1 recommendation: Get an Enterprise solution

What if we don't have the budget? Well there is some hope.

[slide]

Windows Server Backup. I know it isn't the best. Heck I wouldn't even call it good. But it is something you already have and it doesn't cost any extra. You can get BMR or System state backups with it pretty easy. It's also supported by Microsoft. They still talk about it in BCDR engagements, trust me.

Another option is Azure Backups. If you have an IaaS DC running in the cloud, Azure Backup can do the work. The big thing here is when on-prem is compromised the cloud-side often is too because of all the connections. Also, Azure security is about as bad as AD in many places so you may not have the access controls here you think. Nonetheless, it works.

By the way, most NAS solutions even off the shelf ones, tend to have Write-Only or Immutible modes that would account for immutable backups. The downside is the security. Immutible means squat if you have root access to the volumes. So that will have to be hardened for that to matter.

[slide]

IFM is "Install From Media". This is a feature of AD that allows you pre-seed the AD database to new domain controllers to reduce replication time. This file includes the NTDS.DIT, the database, the SYSVOL, and a few registry items.

The folks at DSInternals figured out a way to take the IFM data and generate a recovery script that will rebuild a DC with nothing shared. Fresh build on a new system with the correct domain, SID, etc. It's pretty cool.

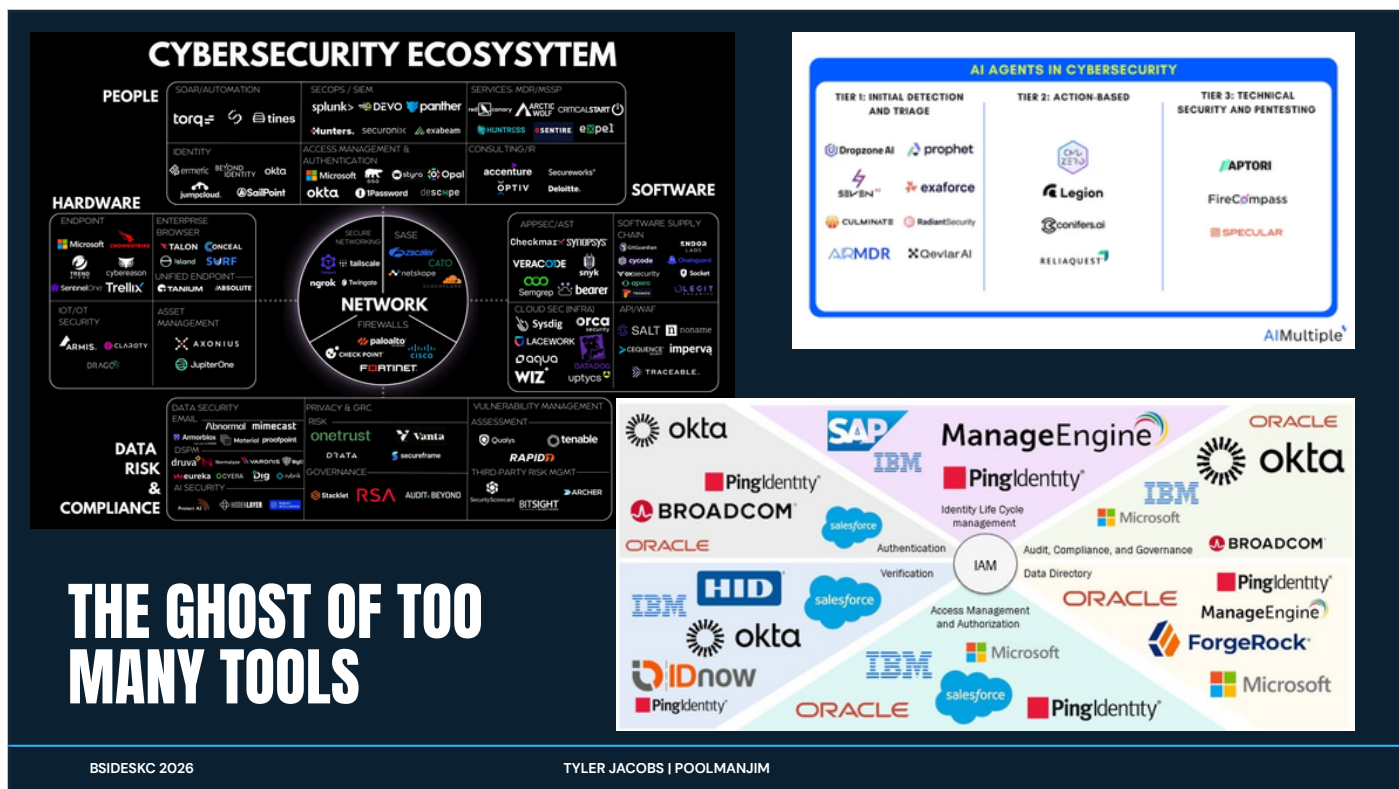
Fun fact: Any enterprise tool that has a "clean os" option or similar, is likely using this behind the scenes.

The IFMs are not encrypted and really are just a blind copy of the AD database, secure them accordingly.

Together those can restore a DC. Its, very neat.

[slide]

To that end I'm working on a collection scripts and stuff to smooth over the IFM + DSInternals process to create a backup solution gives some more flexibility. Keep an eye on my github for that.



Slide Time: 3 min

I love this slide. I intentionally broke all the rules.

"Limit all the words on your slides". Nah. I'll use all the words!

There are uncountable tools for cybersecurity and identity management. I guarantee you this is not comprehensive.

Toss in the new AI tools and we have even more. It's too much for any one person to know and keep track of.

What often happens is the company buys one tool, uses half (at best) of its capabilities, and forgets about it. A few years later a new C-suite pops in and buys their tool of choice and the cycle repeats.

Don't chase shiny, new, buzzwordy solutions. Look at what is already deployed and make that work for you if it can.

The vendors don't help much. If they can they'll sell you the Nile, the Pyramids and the Sphinx's nose. It's their job. Make sure you know what you're getting into with any tools.

Also pay attention to these tool's permissions. I've seen too many of them want domain admin rights, local admin rights, or SYSTEM rights on a DC.

If the tools require those rights, let's make sure they have separate instances with separate creds or move the existing instances to be more secure. If you have an agent running SYSTEM on a DC, what can it do? EVERYTHING.

Cyber teams, your tools are cool and great but ask the question: What if my tool is the tool that gets compromised? All the analytics in the world don't make the side channel attacks against your tool non-existent.

OPERATIONAL RISK IS RISK

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 2 min

If someone were to ask me whether I would have a killer vulnerability scanning tool or a monitoring tool for AD, I'd answer monitoring. I don't mean security monitoring either. I mean simple system performance monitoring.

Why?

Because Operational Risk is still risk!

Our responsibility as administrators are to ensure that the business services stay available and online. The moment that is not longer true, the calculus falls a part and the "value" goes away.

Vuln scanners are cool. SIEMs are necessary. Are either more important than knowing if the services we offer are healthy?

A downed system is no better than a compromised system when you talk with business leaders.

If your bank is offline, how much money is lost? If your healthcare system is down what is the cost there? Think about it.

WHAT DO YOU HAVE ALREADY?

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 1 minute

This has been mentioned before, but the first thing to consider is what tools you may already have. Are they perfect? Maybe not, but they're a hell of a lot cheaper than buying something else.

I'm also obliged to say that I'm almost 100% going to not mention the tool(s) you're thinking of here. There are some many in this space. I picked what I know. If it works, it's not stupid.

[slide]

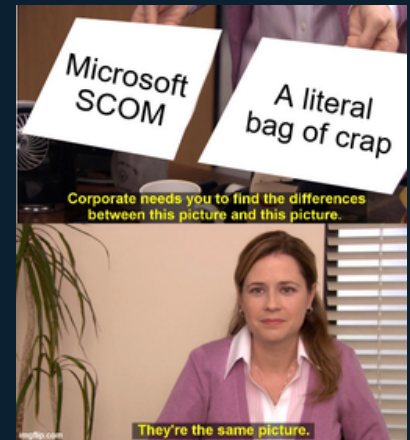
Speaking of obliged tools. There is a solid chance you have SCOM. If you have the system center suite, you have SCOM.

Personally, I hate SCOM. I hate almost everything about it, but it is there for most places.

[slide]

WHAT DO YOU HAVE ALREADY?

Systems Center Operations Manager
(SCOM)



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 1 minute

This has been mentioned before, but the first thing to consider is what tools you may already have. Are they perfect? Maybe not, but they're a hell of a lot cheaper than buying something else.

I'm also obliged to say that I'm almost 100% going to not mention the tool(s) you're thinking of here. There are some many in this space. I picked what I know. If it works, it's not stupid.

[slide]

Speaking of obliged tools. There is a solid chance you have SCOM. If you have the system center suite, you have SCOM.

Personally, I hate SCOM. I hate almost everything about it, but it is there for most places.

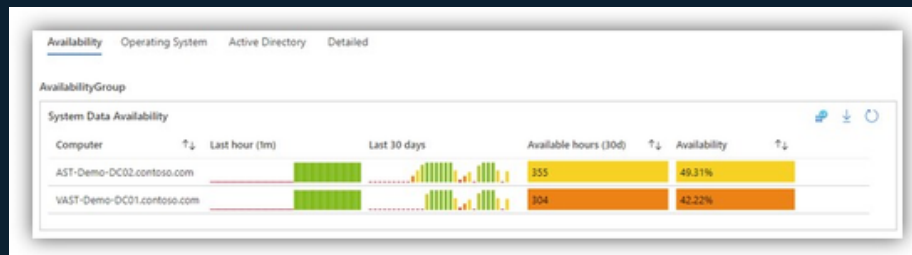
[slide]

WHAT DO YOU HAVE ALREADY?

Systems Center Operations Manager
(SCOM)

Azure Monitor (Paid)

<https://learn.microsoft.com/en-us/azure/azure-monitor/fundamentals/overview>



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 1 minute

Azure Monitor is actually a very solid tool. You can build neat dashboards that execs love but also do stuff engineers care about.

The biggest downside with Azure Monitor are that it uses Log Analytics as a data source and if you haven't used Log Analytics, they can get VERY expensive very quickly. This requires lots of attention to refine.

I suggest starting with low retention and only a few things ingested and work up.

With Azure Monitor you can find free workbooks online to help setup the dashboards and what not.

References and Resources:

- <https://github.com/dmrellan/Active-Directory-Performance-Assessment-with-Azure-Monitor-workbook>
- <https://github.com/microsoft/AzureMonitorCommunity>
- https://www.zabbix.com/documentation/7.0/en/manual/installation/getting_zabbix
- <https://www.zabbix.com/manuals>

<https://github.com/ActiveDirectoryKC/Zabbix-AD-Health-Monitors>

PERFORMANCE / RELIABILITY MONITORING

WHAT DO YOU HAVE ALREADY?

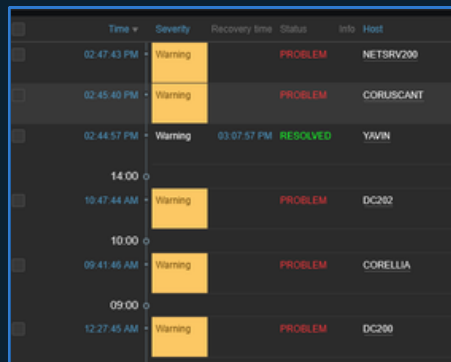
Systems Center Operations Manager
(SCOM)

Azure Monitor (Paid)

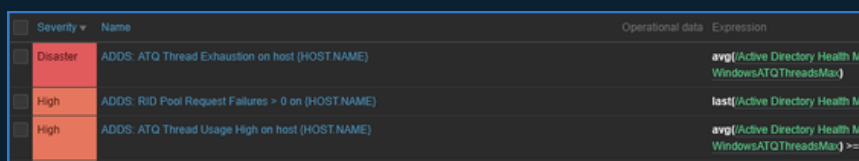
<https://learn.microsoft.com/en-us/azure/azure-monitor/fundamentals/overview>

Zabbix (Free/Paid)

https://www.zabbix.com/documentation/7.0/en/manual/installation/getting_zabbix



Time	Severity	Recovery time	Status	Info	Host
02:47:43 PM	Warning		PROBLEM		NETSRV200
02:45:40 PM	Warning		PROBLEM		CORUSCANT
02:44:57 PM	Warning	03:07:57 PM	RESOLVED		YAVIN
14:00					
10:47:44 AM	Warning		PROBLEM		DC202
10:00					
09:41:45 AM	Warning		PROBLEM		CORELLIA
09:00					
12:27:45 AM	Warning		PROBLEM		DC200



Severity	Name	Operational data	Expression
Disaster	ADDS: ATQ Thread Exhaustion on host (HOSTNAME)		avg((Active Directory Health Mo WindowsATQThreadsMa...))
High	ADDS: RiD Pool Request Failures > 0 on (HOSTNAME)		last((Active Directory Health Mo WindowsATQThreadsMa...))
High	ADDS: ATQ Thread Usage High on host (HOSTNAME)		avg((Active Directory Health Mo WindowsATQThreadsMa...)) >= {

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 1 minute

My personal favorite tool on the list is Zabbix. Sure there are others but I've used this the most in labs and it works really good.

The biggest disadvantages to Zabbix is that is a bit confusing out of the box and it doesn't have super great Windows support. They support Windows but it almost always seems like an after thought.

The good news is that I put a AD-specific template for Zabbix on my github as a starting point for anyone going down that road. I encourage you to give that a look if you're interested in Zabbix.

MONITORING ACTION PLAN

- **Configure AD Advanced Auditing**

- Group Policy \ Computer Settings \ Security Settings \ Security Options
- Group Policy \ Computer Settings \ Security Settings \ Windows Settings \ Advanced Audit Policies

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 2 minutes

How do we get started with monitoring?

[slide]

Start with Advanced Audit Policies. Do not confuse these with traditional audit policies. The two are incompatible.

You can get very granular with what you're reporting on with these and it is important to set them up right (details later).

[slide]

Data Collector Sets don't get tons of love. They are kind of clunky but they are a good means gathering period views of the performance on a system. They can be scheduled and do get a lot of information. I recommend looking into them if you haven't.

[slide]

Get an actual monitoring/alerting tool, set it up, and configure it to alert.

My recommendation is, of course, Zabbix, but use what makes sense to you. Just make sure

you're using it.

[slide]

None of this makes any sense if you don't use it. Make sure someone looks at the data and is assessing reliability and responding to alerts coming out of this.

MONITORING ACTION PLAN

- **Configure AD Advanced Auditing**
 - Group Policy \ Computer Settings \ Security Settings \ Security Options
 - Group Policy \ Computer Settings \ Security Settings \ Windows Settings \ Advanced Audit Policies
- **Configure Data Collector Sets**
 - Perfmon \ Data Collector Sets
 - <https://techcommunity.microsoft.com/blog/coreinfrastructureandsecurityblog/taming-perfmon-data-collector-sets/255521>

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 2 minutes

How do we get started with monitoring?

[slide]

Start with Advanced Audit Policies. Do not confuse these with traditional audit policies. The two are incompatible.

You can get very granular with what you're reporting on with these and it is important to set them up right (details later).

[slide]

Data Collector Sets don't get tons of love. They are kind of clunky but they are a good means gathering period views of the performance on a system. They can be scheduled and do get a lot of information. I recommend looking into them if you haven't.

[slide]

Get an actual monitoring/alerting tool, set it up, and configure it to alert.

My recommendation is, of course, Zabbix, but use what makes sense to you. Just make sure

you're using it.

[slide]

None of this makes any sense if you don't use it. Make sure someone looks at the data and is assessing reliability and responding to alerts coming out of this.

MONITORING ACTION PLAN

- **Configure AD Advanced Auditing**
 - Group Policy \ Computer Settings \ Security Settings \ Security Options
 - Group Policy \ Computer Settings \ Security Settings \ Windows Settings \ Advanced Audit Policies
- **Configure Data Collector Sets**
 - Perfmon \ Data Collector Sets
 - <https://techcommunity.microsoft.com/blog/coreinfrastructureandsecurityblog/taming-perfmon-data-collector-sets/255521>
- **Get a tool (Zabbix)**
 - My github has a template for AD
 - <https://github.com/ActiveDirectoryKC/Zabbix-AD-Health-Monitors>

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 2 minutes

How do we get started with monitoring?

[slide]

Start with Advanced Audit Policies. Do not confuse these with traditional audit policies. The two are incompatible.

You can get very granular with what you're reporting on with these and it is important to set them up right (details later).

[slide]

Data Collector Sets don't get tons of love. They are kind of clunky but they are a good means gathering period views of the performance on a system. They can be scheduled and do get a lot of information. I recommend looking into them if you haven't.

[slide]

Get an actual monitoring/alerting tool, set it up, and configure it to alert.

My recommendation is, of course, Zabbix, but use what makes sense to you. Just make sure

you're using it.

[slide]

None of this makes any sense if you don't use it. Make sure someone looks at the data and is assessing reliability and responding to alerts coming out of this.

MONITORING ACTION PLAN

- Configure AD Advanced Auditing
 - Group Policy \ Computer Settings \ Security Settings \ Security Options
 - Group Policy \ Computer Settings \ Security Settings \ Windows Settings \ Advanced Audit Policies
- Configure Data Collector Sets
 - Perfmon \ Data Collector Sets
 - <https://techcommunity.microsoft.com/blog/coreinfrastructureandsecurityblog/taming-perfmon-data-collector-sets/255521>
- Get a tool (Zabbix)
 - My github has a template for AD
 - <https://github.com/ActiveDirectoryKC/Zabbix-AD-Health-Monitors>
- Review it the monitors / Alert

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 2 minutes

How do we get started with monitoring?

[slide]

Start with Advanced Audit Policies. Do not confuse these with traditional audit policies. The two are incompatible.

You can get very granular with what you're reporting on with these and it is important to set them up right (details later).

[slide]

Data Collector Sets don't get tons of love. They are kind of clunky but they are a good means gathering period views of the performance on a system. They can be scheduled and do get a lot of information. I recommend looking into them if you haven't.

[slide]

Get an actual monitoring/alerting tool, set it up, and configure it to alert.

My recommendation is, of course, Zabbix, but use what makes sense to you. Just make sure

you're using it.

[slide]

None of this makes any sense if you don't use it. Make sure someone looks at the data and is assessing reliability and responding to alerts coming out of this.

THE GHOST OF PERFECTION

Baselines, STIGS, & Benchmarks



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Section Time: 12 Min

Slide Time: 1 min

Best practices are always a nebulous concept. Whose best practices are we using? Why do they get to decide?

The industry standard on this is baselines and benchmarks. They're co developed with the vendors with the various bodies who issue them.

MICROSOFT SECURITY BASELINES

MICROSOFT SECURITY AND COMPLIANCE TOOLKIT

- Free download from MS
 - <https://www.microsoft.com/en-us/download/details.aspx?id=55319>
- Per-OS Version
- Includes
 - GPO Templates
 - Policy Analyzer
 - Policy to Reg Key Reference
 - LGPO



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 2 min

For most places, start with the Microsoft Baselines. It's a free download and a little clunky to use, but it will help you get a good start. With the download you'll get "drop in" GPO templates and there are a couple of tools: Policy Analyzer, which can compare what you have currently versus the baseline; and LGPO which can be used to audit and edit local group policy.

There is one other thing that these include that has been a game changer for me so far. The download includes a download of a collection of excel spreadsheets that include the mappings for most Group Policy settings to their corresponding Registry Keys. This applies to most policies, but not any of the "Security Options" since those aren't registry settings. This spreadsheet is a really good resource. I even have it pinned in excel and use it often.

The downsides to MS Security Baselines are they are Windows-only, but you're in an Active Directory hardening talk. If you were expecting Linux hardening tips see me after and tell you to ask someone else. The other disadvantage is they are somewhat limited. If you compare them to the other two I'm going to talk about, they are not as comprehensive. But remember "Perfect is the enemy of good".

Resources and References:

- <https://www.microsoft.com/en-us/download/details.aspx?id=55319>

- <https://learn.microsoft.com/en-us/windows/security/operating-system-security/device-manageme>

DISA SITGS

DISA = DEFENSE INFORMATION SECURITY AGENCY

STIG = SECURITY TECHNICAL IMPLEMENTATION GUIDE

- US Gov. focused.
- Not just Microsoft
- More comprehensive than MS
- Needs some tweaking
- <https://www.cyber.mil/stigs/>
- Includes
 - GPO Templates
 - SCAP Tool
 - Guides



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: ~2 min

I could ask anyone who's used these raise their hands but this is not a game of Spot the Fed.

DISA STIGs are a type of benchmarking that is put out by the US Government for the US Government. I know that inspires tons of confidence, but give them a chance here.

The cool thing is there are STIGs for lots of different things, including lots outside of Microsoft.

For Microsoft they include drop-in GPO policy templates and even Ansible-based options.

STIGs tend to be more comprehensive than the Microsoft Baselines. My favorite thing about STIGs is the SCAP tool. This is a free download and it will do local or remote scanning of systems based on the specified STIG benchmark you included with the scan. The usual scan permissions apply, but it really can get you a good picture of the compliance.

The big downside of STIGs is that they are very, very, very much focused on the US Government, specifically the Department of Defense. If you look there are settings that really only apply to the US Government. The two I always remember are the requirement to use US Government Root CAs and to use US Government Time Servers. You can obviously ignore those specific findings and use that more as a reminder or a template for making sure you have your own secured Root CA and a known good time source.

You're all doing those things right?

I recommend using these because of the scanner and the increased coverage over MS Baselines. They're probably my favorite long term option because of how simple the SCAP tool is.

ADHD tangent: The format for the SCAP tool scans is kind of wierd. I looked at it a long time ago and decided it wasn't worth my time. I have it on good authority that you can use your LLM of choice to make your own SCAP Benchmarks.

Resources and References:

- <https://www.cyber.mil/stigs/>
- <https://cyber.trackr.live/stig>

Cyber.Trackr is a good quick viewer for STIG settings.

CIS BENCHMARKS

CIS = CENTER FOR INTERNET SECURITY

- Like STIGs but less government
- Requires email address for the guide
- CIS CAT-Lite Scanner (req. email)
 - Limited to client OSes
- Extremely comprehensive = Harder to navigate
- <https://downloads.cisecurity.org/#/>

	Lite	Pro
CIS Benchmarks supported	Select*	80+
Requires a license key		✓
Graphical User and Command Line Interface (GUI and CLI) Options	✓	✓
CIS Controls Assessment Module	✓	✓
Measure assessment results on conformity scale of 0-100	✓	✓
Evidence-based reports in HTML format	✓	✓
Perform unlimited scans	✓	✓
Assess against other SCAP content (i.e. DISA STIGS)		✓
Remotely assess endpoints	✓	✓
Customize CIS Benchmark content via CIS WorkBench		✓
Access to CIS Benchmarks in XML/XCCDF/OVAL		✓
Assess multiple machines at one time via centralized workflows	✓	✓
Analyze assessment results in CIS-CAT Pro Dashboard		✓
Evidence-based reports in Text, Excel, and XML (ARF) formats		✓

*Microsoft Windows 10 & 11, Ubuntu, and Google Chrome

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 1 min

CIS Benchmarks compare a lot to DISA STIGs. The big difference are CIS Benchmarks can go down some rabbit holes and can be super comprehensive. They are, admittedly, the ones I'm least familiar with.

They're not bad and they are more universal than DISA STIGS so there aren't any "US Government" items in them, and they offer solid guidelines for the items instead. My biggest dislike of CIS Benchmarks are that they 1) require an email to download the PDF guides and 2) they require you to pay for their scanning tool. Compliance checks depend on either their paid tool or third parties.

CIS will show up in pretty much any non-US Government compliance lists.

Resources and References:

- <https://downloads.cisecurity.org/#/>
- <https://learn.cisecurity.org/cis-cat-lite>
- <https://www.huntress.com/cybersecurity-101/topic/what-are-cis-benchmarks>
- <https://netwrix.com/en/resources/blog/cis-security-benchmarks/>

Other tools with CIS Scanning

- <https://wazuh.com/>
- <https://github.com/scipag/HardeningKitty>

NOTABLE SECURITY SETTINGS

LDAP Signing

<https://learn.microsoft.com/en-us/windows-server/identity/manage-ldap-signing-group-policy?tabs=windows-server-2025#identify-clients-using-unsigned-ldap-binds>

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

(NEED NOTES)

There are literally hundreds of security settings and it is impossible to call out all the meaningful ones here. Instead, I chose some that are either a really big deal or have a gotcha associated.

LDAP Signing

- LDAP signing is one of the easier ones to get in. It doesn't mean LDAPS strictly, but I recommend deploying LDAPS for it as that meets it.
- LDAP Channel Binding is useful as it prevents some MITM attacks. The challenge here is poorly supported by older OSes, particularly older Linux.

For both of these there are audit policies, configure those.
(References below)

SMB Signing

- This is an easy one to get enabled and protects against several attacks. I've not seen much stuff have issues with it these days.

NTLM Hardening

- This covers the Microsoft push to end NTLM.
- There are two types of NTLM: v1 and v2. v1 needs to die in fire so if you're using it, get rid of it.

- v2 is old and needs to go, but it is still needed by a lot of apps.
- There are audit policies to nail these down.

Kerberos Delegations

- Kerberos Delegation is impersonation and it by itself isn't bad, but has options that are horrifying.
- Basically, find anything running unconstrained delegation or protocol translation.

Kerberos Encryption Types

- Microsoft has gone to town on these lately with the demise of RC4. If you're still using it, get off it.
- At a minimum start finding RC4 stuff and rooting it out and make sure AES is enabled wherever possible.

-- References

LDAP References

- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/ldap-signing>
- <https://support.microsoft.com/en-us/topic/2020-2023-and-2024-ldap-channel-binding-and-ldap-signing-requirements-for-windows-kb4520412-ef185fb8-00f7-167d-744c-f299a66fc00a>
- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/ldap-client-performance-counters>
- learn.microsoft.com/en-us/windows-server/identity/ad-ds/configure-ldap-signing-certificates?tabs=microsoft-enterprise-ca
- <https://learn.microsoft.com/en-us/windows-server/identity/manage-ldap-signing-group-policy?tabs=windows-server-2025>
- <https://support.microsoft.com/en-us/topic/kb4034879-use-the-ldapenforcechannelbinding-registry-entry-to-make-ldap-authentication-over-ssl-tls-more-secure-e9ecfa27-5e57-8519-6ba3-d2c06b21812e>

SMB

- <https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-signing-overview>

NTLM

- <https://syfuhs.net/deprecating-ntlm-is-easy-and-other-lies-we-tell-ourselves>
- <https://techcommunity.microsoft.com/blog/windows-itpro-blog/advancing-windows-security-disabling-ntlm-by-default/4489526>
- <https://support.microsoft.com/en-us/topic/overview-of-ntlm-auditing-enhancements-in-windows-11-version-24h2-and-windows-server-2025-b7ead732-6fc5-46a3-a943-27a4571d9e7b>
- <https://support.microsoft.com/en-us/topic/upcoming-changes-to-ntlmv1-in-windows-11-version-24h2-and-windows-server-2025-c0554217-cdbc-420f-b47c-e02b2db49b2e>

Kerberos Delegation

- <https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-constrained-delegation-overview>
- <https://learn.microsoft.com/en-us/archive/blogs/poshchap/security-focus-analysing-account-is-sensitive-and-cannot-be-delegated-for-privileged-accounts>
- [https://learn.microsoft.com/en-us/previous-versions/tn-archive/cc995228\(v=technet.10\)?redirectedfrom=MSDN](https://learn.microsoft.com/en-us/previous-versions/tn-archive/cc995228(v=technet.10)?redirectedfrom=MSDN)
- <https://syfuhs.net/understanding-identity-delegation>

Kerberos Encryption

- <https://syfuhs.net/lessons-in-disabling-rc4-in-active-directory>
- <https://www.microsoft.com/en-us/windows-server/blog/2025/12/03/beyond-rc4-for-windows-authentication/>
- <https://support.microsoft.com/en-us/topic/how-to-manage-kerberos-kdc-usage-of-rc4-for-service-account-ticket-issuance-changes-related-to-cve-2026-20833-1ebcda33-720a-4da8-93c1-b0496e1910dc>

NOTABLE SECURITY SETTINGS

LDAP Signing

<https://learn.microsoft.com/en-us/windows-server/identity/manage-ldap-signing-group-policy?tabs=windows-server-2025#identify-clients-using-unsigned-ldap-binds>

LDAP Channel Binding

Reg Add
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\NTDS\Diagnostics /v "16 LDAP Interface Events" /t REG_DWORD /d 2

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

(NEED NOTES)

There are literally hundreds of security settings and it is impossible to call out all the meaningful ones here. Instead, I chose some that are either a really big deal or have a gotcha associated.

LDAP Signing

- LDAP signing is one of the easier ones to get in. It doesn't mean LDAPS strictly, but I recommend deploying LDAPS for it as that meets it.
- LDAP Channel Binding is useful as it prevents some MITM attacks. The challenge here is poorly supported by older OSes, particularly older Linux.

For both of these there are audit policies, configure those.
(References below)

SMB Signing

- This is an easy one to get enabled and protects against several attacks. I've not seen much stuff have issues with it these days.

NTLM Hardening

- This covers the Microsoft push to end NTLM.
- There are two types of NTLM: v1 and v2. v1 needs to die in fire so if you're using it, get rid of it.

- v2 is old and needs to go, but it is still needed by a lot of apps.
- There are audit policies to nail these down.

Kerberos Delegations

- Kerberos Delegation is impersonation and it by itself isn't bad, but has options that are horrifying.
- Basically, find anything running unconstrained delegation or protocol translation.

Kerberos Encryption Types

- Microsoft has gone to town on these lately with the demise of RC4. If you're still using it, get off it.
- At a minimum start finding RC4 stuff and rooting it out and make sure AES is enabled wherever possible.

-- References

LDAP References

- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/ldap-signing>
- <https://support.microsoft.com/en-us/topic/2020-2023-and-2024-ldap-channel-binding-and-ldap-signing-requirements-for-windows-kb4520412-ef185fb8-00f7-167d-744c-f299a66fc00a>
- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/ldap-client-performance-counters>
- learn.microsoft.com/en-us/windows-server/identity/ad-ds/configure-ldap-signing-certificates?tabs=microsoft-enterprise-ca
- <https://learn.microsoft.com/en-us/windows-server/identity/manage-ldap-signing-group-policy?tabs=windows-server-2025>
- <https://support.microsoft.com/en-us/topic/kb4034879-use-the-ldapenforcechannelbinding-registry-entry-to-make-ldap-authentication-over-ssl-tls-more-secure-e9ecfa27-5e57-8519-6ba3-d2c06b21812e>

SMB

- <https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-signing-overview>

NTLM

- <https://syfuhs.net/deprecating-ntlm-is-easy-and-other-lies-we-tell-ourselves>
- <https://techcommunity.microsoft.com/blog/windows-itpro-blog/advancing-windows-security-disabling-ntlm-by-default/4489526>
- <https://support.microsoft.com/en-us/topic/overview-of-ntlm-auditing-enhancements-in-windows-11-version-24h2-and-windows-server-2025-b7ead732-6fc5-46a3-a943-27a4571d9e7b>
- <https://support.microsoft.com/en-us/topic/upcoming-changes-to-ntlmv1-in-windows-11-version-24h2-and-windows-server-2025-c0554217-cdbc-420f-b47c-e02b2db49b2e>

Kerberos Delegation

- <https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-constrained-delegation-overview>
- <https://learn.microsoft.com/en-us/archive/blogs/poshchap/security-focus-analysing-account-is-sensitive-and-cannot-be-delegated-for-privileged-accounts>
- [https://learn.microsoft.com/en-us/previous-versions/tn-archive/cc995228\(v=technet.10\)?redirectedfrom=MSDN](https://learn.microsoft.com/en-us/previous-versions/tn-archive/cc995228(v=technet.10)?redirectedfrom=MSDN)
- <https://syfuhs.net/understanding-identity-delegation>

Kerberos Encryption

- <https://syfuhs.net/lessons-in-disabling-rc4-in-active-directory>
- <https://www.microsoft.com/en-us/windows-server/blog/2025/12/03/beyond-rc4-for-windows-authentication/>
- <https://support.microsoft.com/en-us/topic/how-to-manage-kerberos-kdc-usage-of-rc4-for-service-account-ticket-issuance-changes-related-to-cve-2026-20833-1ebcda33-720a-4da8-93c1-b0496e1910dc>

NOTABLE SECURITY SETTINGS

LDAP Signing

<https://learn.microsoft.com/en-us/windows-server/identity/manage-ldap-signing-group-policy?tabs=windows-server-2025#identify-clients-using-unsigned-ldap-binds>

LDAP Channel Binding

Reg Add
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\NTDS\Diagnostics /v "16 LDAP Interface Events" /t REG_DWORD /d 2

SMB Signing

<https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-signing-overview>

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

(NEED NOTES)

There are literally hundreds of security settings and it is impossible to call out all the meaningful ones here. Instead, I chose some that are either a really big deal or have a gotcha associated.

LDAP Signing

- LDAP signing is one of the easier ones to get in. It doesn't mean LDAPS strictly, but I recommend deploying LDAPS for it as that meets it.
- LDAP Channel Binding is useful as it prevents some MITM attacks. The challenge here is poorly supported by older OSes, particularly older Linux.

For both of these there are audit policies, configure those.
(References below)

SMB Signing

- This is an easy one to get enabled and protects against several attacks. I've not seen much stuff have issues with it these days.

NTLM Hardening

- This covers the Microsoft push to end NTLM.
- There are two types of NTLM: v1 and v2. v1 needs to die in fire so if you're using it, get rid of it.

- v2 is old and needs to go, but it is still needed by a lot of apps.
- There are audit policies to nail these down.

Kerberos Delegations

- Kerberos Delegation is impersonation and it by itself isn't bad, but has options that are horrifying.
- Basically, find anything running unconstrained delegation or protocol translation.

Kerberos Encryption Types

- Microsoft has gone to town on these lately with the demise of RC4. If you're still using it, get off it.
- At a minimum start finding RC4 stuff and rooting it out and make sure AES is enabled wherever possible.

-- References

LDAP References

- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/ldap-signing>
- <https://support.microsoft.com/en-us/topic/2020-2023-and-2024-ldap-channel-binding-and-ldap-signing-requirements-for-windows-kb4520412-ef185fb8-00f7-167d-744c-f299a66fc00a>
- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/ldap-client-performance-counters>
- learn.microsoft.com/en-us/windows-server/identity/ad-ds/configure-ldap-signing-certificates?tabs=microsoft-enterprise-ca
- <https://learn.microsoft.com/en-us/windows-server/identity/manage-ldap-signing-group-policy?tabs=windows-server-2025>
- <https://support.microsoft.com/en-us/topic/kb4034879-use-the-ldapenforcechannelbinding-registry-entry-to-make-ldap-authentication-over-ssl-tls-more-secure-e9ecfa27-5e57-8519-6ba3-d2c06b21812e>

SMB

- <https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-signing-overview>

NTLM

- <https://syfuhs.net/deprecating-ntlm-is-easy-and-other-lies-we-tell-ourselves>
- <https://techcommunity.microsoft.com/blog/windows-itpro-blog/advancing-windows-security-disabling-ntlm-by-default/4489526>
- <https://support.microsoft.com/en-us/topic/overview-of-ntlm-auditing-enhancements-in-windows-11-version-24h2-and-windows-server-2025-b7ead732-6fc5-46a3-a943-27a4571d9e7b>
- <https://support.microsoft.com/en-us/topic/upcoming-changes-to-ntlmv1-in-windows-11-version-24h2-and-windows-server-2025-c0554217-cdbc-420f-b47c-e02b2db49b2e>

Kerberos Delegation

- <https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-constrained-delegation-overview>
- <https://learn.microsoft.com/en-us/archive/blogs/poshchap/security-focus-analysing-account-is-sensitive-and-cannot-be-delegated-for-privileged-accounts>
- [https://learn.microsoft.com/en-us/previous-versions/tn-archive/cc995228\(v=technet.10\)?redirectedfrom=MSDN](https://learn.microsoft.com/en-us/previous-versions/tn-archive/cc995228(v=technet.10)?redirectedfrom=MSDN)
- <https://syfuhs.net/understanding-identity-delegation>

Kerberos Encryption

- <https://syfuhs.net/lessons-in-disabling-rc4-in-active-directory>
- <https://www.microsoft.com/en-us/windows-server/blog/2025/12/03/beyond-rc4-for-windows-authentication/>
- <https://support.microsoft.com/en-us/topic/how-to-manage-kerberos-kdc-usage-of-rc4-for-service-account-ticket-issuance-changes-related-to-cve-2026-20833-1ebcda33-720a-4da8-93c1-b0496e1910dc>

NOTABLE SECURITY SETTINGS

LDAP Signing

<https://learn.microsoft.com/en-us/windows-server/identity/manage-ldap-signing-group-policy?tabs=windows-server-2025#identify-clients-using-unsigned-ldap-binds>

LDAP Channel Binding

Reg Add
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\NTDS\Diagnostics /v "16 LDAP Interface Events" /t REG_DWORD /d 2

SMB Signing

<https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-signing-overview>

NTLM Hardening

- NTLMv1 blocking forced enforcement Oct 2026
- Auditing: GPMC \ Computer Settings \ Admin. Templates \ System \ NTLM \ NTLM Enhanced Logging

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

(NEED NOTES)

There are literally hundreds of security settings and it is impossible to call out all the meaningful ones here. Instead, I chose some that are either a really big deal or have a gotcha associated.

LDAP Signing

- LDAP signing is one of the easier ones to get in. It doesn't mean LDAPS strictly, but I recommend deploying LDAPS for it as that meets it.

- LDAP Channel Binding is useful as it prevents some MITM attacks. The challenge here is poorly supported by older OSes, particularly older Linux.

For both of these there are audit policies, configure those.
(References below)

SMB Signing

- This is an easy one to get enabled and protects against several attacks. I've not seen much stuff have issues with it these days.

NTLM Hardening

- This covers the Microsoft push to end NTLM.

- There are two types of NTLM: v1 and v2. v1 needs to die in fire so if you're using it, get rid of it.

- v2 is old and needs to go, but it is still needed by a lot of apps.
- There are audit policies to nail these down.

Kerberos Delegations

- Kerberos Delegation is impersonation and it by itself isn't bad, but has options that are horrifying.
- Basically, find anything running unconstrained delegation or protocol translation.

Kerberos Encryption Types

- Microsoft has gone to town on these lately with the demise of RC4. If you're still using it, get off it.
- At a minimum start finding RC4 stuff and rooting it out and make sure AES is enabled wherever possible.

-- References

LDAP References

- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/ldap-signing>
- <https://support.microsoft.com/en-us/topic/2020-2023-and-2024-ldap-channel-binding-and-ldap-signing-requirements-for-windows-kb4520412-ef185fb8-00f7-167d-744c-f299a66fc00a>
- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/ldap-client-performance-counters>
- learn.microsoft.com/en-us/windows-server/identity/ad-ds/configure-ldap-signing-certificates?tabs=microsoft-enterprise-ca
- <https://learn.microsoft.com/en-us/windows-server/identity/manage-ldap-signing-group-policy?tabs=windows-server-2025>
- <https://support.microsoft.com/en-us/topic/kb4034879-use-the-ldapenforcechannelbinding-registry-entry-to-make-ldap-authentication-over-ssl-tls-more-secure-e9ecfa27-5e57-8519-6ba3-d2c06b21812e>

SMB

- <https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-signing-overview>

NTLM

- <https://syfuhs.net/deprecating-ntlm-is-easy-and-other-lies-we-tell-ourselves>
- <https://techcommunity.microsoft.com/blog/windows-itpro-blog/advancing-windows-security-disabling-ntlm-by-default/4489526>
- <https://support.microsoft.com/en-us/topic/overview-of-ntlm-auditing-enhancements-in-windows-11-version-24h2-and-windows-server-2025-b7ead732-6fc5-46a3-a943-27a4571d9e7b>
- <https://support.microsoft.com/en-us/topic/upcoming-changes-to-ntlmv1-in-windows-11-version-24h2-and-windows-server-2025-c0554217-cdbc-420f-b47c-e02b2db49b2e>

Kerberos Delegation

- <https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-constrained-delegation-overview>
- <https://learn.microsoft.com/en-us/archive/blogs/poshchap/security-focus-analysing-account-is-sensitive-and-cannot-be-delegated-for-privileged-accounts>
- [https://learn.microsoft.com/en-us/previous-versions/tn-archive/cc995228\(v=technet.10\)?redirectedfrom=MSDN](https://learn.microsoft.com/en-us/previous-versions/tn-archive/cc995228(v=technet.10)?redirectedfrom=MSDN)
- <https://syfuhs.net/understanding-identity-delegation>

Kerberos Encryption

- <https://syfuhs.net/lessons-in-disabling-rc4-in-active-directory>
- <https://www.microsoft.com/en-us/windows-server/blog/2025/12/03/beyond-rc4-for-windows-authentication/>
- <https://support.microsoft.com/en-us/topic/how-to-manage-kerberos-kdc-usage-of-rc4-for-service-account-ticket-issuance-changes-related-to-cve-2026-20833-1ebcda33-720a-4da8-93c1-b0496e1910dc>

NOTABLE SECURITY SETTINGS

LDAP Signing

<https://learn.microsoft.com/en-us/windows-server/identity/manage-ldap-signing-group-policy?tabs=windows-server-2025#identify-clients-using-unsigned-ldap-binds>

LDAP Channel Binding

Reg Add
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\NTDS\Diagnostics /v "16 LDAP Interface Events" /t REG_DWORD /d 2

SMB Signing

<https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-signing-overview>

NTLM Hardening

- NTLMv1 blocking forced enforcement Oct 2026
- Auditing: GPMC \ Computer Settings \ Admin. Templates \ System \ NTLM \ NTLM Enhanced Logging

Kerberos Encryption Types

Get-ADUser -Filter "msDS-SupportedEncryptionTypes' -band 0x4 -or 'msDS-SupportedEncryptionTypes' -band 0x1 -or 'msDS-SupportedEncryptionTypes' -band 0x2" -Properties msDS-SupportedEncryptionTypes

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

(NEED NOTES)

There are literally hundreds of security settings and it is impossible to call out all the meaningful ones here. Instead, I chose some that are either a really big deal or have a gotcha associated.

LDAP Signing

- LDAP signing is one of the easier ones to get in. It doesn't mean LDAPS strictly, but I recommend deploying LDAPS for it as that meets it.

- LDAP Channel Binding is useful as it prevents some MITM attacks. The challenge here is poorly supported by older OSes, particularly older Linux.

For both of these there are audit policies, configure those.
(References below)

SMB Signing

- This is an easy one to get enabled and protects against several attacks. I've not seen much stuff have issues with it these days.

NTLM Hardening

- This covers the Microsoft push to end NTLM.
- There are two types of NTLM: v1 and v2. v1 needs to die in fire so if you're using it, get rid of it.

- v2 is old and needs to go, but it is still needed by a lot of apps.
- There are audit policies to nail these down.

Kerberos Delegations

- Kerberos Delegation is impersonation and it by itself isn't bad, but has options that are horrifying.
- Basically, find anything running unconstrained delegation or protocol translation.

Kerberos Encryption Types

- Microsoft has gone to town on these lately with the demise of RC4. If you're still using it, get off it.
- At a minimum start finding RC4 stuff and rooting it out and make sure AES is enabled wherever possible.

-- References

LDAP References

- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/ldap-signing>
- <https://support.microsoft.com/en-us/topic/2020-2023-and-2024-ldap-channel-binding-and-ldap-signing-requirements-for-windows-kb4520412-ef185fb8-00f7-167d-744c-f299a66fc00a>
- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/ldap-client-performance-counters>
- learn.microsoft.com/en-us/windows-server/identity/ad-ds/configure-ldap-signing-certificates?tabs=microsoft-enterprise-ca
- <https://learn.microsoft.com/en-us/windows-server/identity/manage-ldap-signing-group-policy?tabs=windows-server-2025>
- <https://support.microsoft.com/en-us/topic/kb4034879-use-the-ldapenforcechannelbinding-registry-entry-to-make-ldap-authentication-over-ssl-tls-more-secure-e9ecfa27-5e57-8519-6ba3-d2c06b21812e>

SMB

- <https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-signing-overview>

NTLM

- <https://syfuhs.net/deprecating-ntlm-is-easy-and-other-lies-we-tell-ourselves>
- <https://techcommunity.microsoft.com/blog/windows-itpro-blog/advancing-windows-security-disabling-ntlm-by-default/4489526>
- <https://support.microsoft.com/en-us/topic/overview-of-ntlm-auditing-enhancements-in-windows-11-version-24h2-and-windows-server-2025-b7ead732-6fc5-46a3-a943-27a4571d9e7b>
- <https://support.microsoft.com/en-us/topic/upcoming-changes-to-ntlmv1-in-windows-11-version-24h2-and-windows-server-2025-c0554217-cdbc-420f-b47c-e02b2db49b2e>

Kerberos Delegation

- <https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-constrained-delegation-overview>
- <https://learn.microsoft.com/en-us/archive/blogs/poshchap/security-focus-analysing-account-is-sensitive-and-cannot-be-delegated-for-privileged-accounts>
- [https://learn.microsoft.com/en-us/previous-versions/tn-archive/cc995228\(v=technet.10\)?redirectedfrom=MSDN](https://learn.microsoft.com/en-us/previous-versions/tn-archive/cc995228(v=technet.10)?redirectedfrom=MSDN)
- <https://syfuhs.net/understanding-identity-delegation>

Kerberos Encryption

- <https://syfuhs.net/lessons-in-disabling-rc4-in-active-directory>
- <https://www.microsoft.com/en-us/windows-server/blog/2025/12/03/beyond-rc4-for-windows-authentication/>
- <https://support.microsoft.com/en-us/topic/how-to-manage-kerberos-kdc-usage-of-rc4-for-service-account-ticket-issuance-changes-related-to-cve-2026-20833-1ebcda33-720a-4da8-93c1-b0496e1910dc>

NOTABLE SECURITY SETTINGS

LDAP Signing

<https://learn.microsoft.com/en-us/windows-server/identity/manage-ldap-signing-group-policy?tabs=windows-server-2025#identify-clients-using-unsigned-ldap-binds>

LDAP Channel Binding

Reg Add
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\NTDS\Diagnostics /v "16 LDAP Interface Events" /t REG_DWORD /d 2

SMB Signing

<https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-signing-overview>

NTLM Hardening

- NTLMv1 blocking forced enforcement Oct 2026
- Auditing: GPMC \ Computer Settings \ Admin. Templates \ System \ NTLM \ NTLM Enhanced Logging

Kerberos Encryption Types

Get-ADUser -Filter "msDS-SupportedEncryptionTypes' -band 0x4 -or 'msDS-SupportedEncryptionTypes' -band 0x1 -or 'msDS-SupportedEncryptionTypes' -band 0x2" -Properties msDS-SupportedEncryptionTypes

Kerberos Delegations

Get-ADComputer -Filter "'TrustedForDelegation' -eq \$true -or 'TrustedToAuthenticateForDelegation' -eq \$true"

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

(NEED NOTES)

There are literally hundreds of security settings and it is impossible to call out all the meaningful ones here. Instead, I chose some that are either a really big deal or have a gotcha associated.

LDAP Signing

- LDAP signing is one of the easier ones to get in. It doesn't mean LDAPS strictly, but I recommend deploying LDAPS for it as that meets it.

- LDAP Channel Binding is useful as it prevents some MITM attacks. The challenge here is poorly supported by older OSes, particularly older Linux.

For both of these there are audit policies, configure those.
(References below)

SMB Signing

- This is an easy one to get enabled and protects against several attacks. I've not seen much stuff have issues with it these days.

NTLM Hardening

- This covers the Microsoft push to end NTLM.

- There are two types of NTLM: v1 and v2. v1 needs to die in fire so if you're using it, get rid of it.

- v2 is old and needs to go, but it is still needed by a lot of apps.
- There are audit policies to nail these down.

Kerberos Delegations

- Kerberos Delegation is impersonation and it by itself isn't bad, but has options that are horrifying.
- Basically, find anything running unconstrained delegation or protocol translation.

Kerberos Encryption Types

- Microsoft has gone to town on these lately with the demise of RC4. If you're still using it, get off it.
- At a minimum start finding RC4 stuff and rooting it out and make sure AES is enabled wherever possible.

-- References

LDAP References

- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/ldap-signing>
- <https://support.microsoft.com/en-us/topic/2020-2023-and-2024-ldap-channel-binding-and-ldap-signing-requirements-for-windows-kb4520412-ef185fb8-00f7-167d-744c-f299a66fc00a>
- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/ldap-client-performance-counters>
- learn.microsoft.com/en-us/windows-server/identity/ad-ds/configure-ldap-signing-certificates?tabs=microsoft-enterprise-ca
- <https://learn.microsoft.com/en-us/windows-server/identity/manage-ldap-signing-group-policy?tabs=windows-server-2025>
- <https://support.microsoft.com/en-us/topic/kb4034879-use-the-ldapenforcechannelbinding-registry-entry-to-make-ldap-authentication-over-ssl-tls-more-secure-e9ecfa27-5e57-8519-6ba3-d2c06b21812e>

SMB

- <https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-signing-overview>

NTLM

- <https://syfuhs.net/deprecating-ntlm-is-easy-and-other-lies-we-tell-ourselves>
- <https://techcommunity.microsoft.com/blog/windows-itpro-blog/advancing-windows-security-disabling-ntlm-by-default/4489526>
- <https://support.microsoft.com/en-us/topic/overview-of-ntlm-auditing-enhancements-in-windows-11-version-24h2-and-windows-server-2025-b7ead732-6fc5-46a3-a943-27a4571d9e7b>
- <https://support.microsoft.com/en-us/topic/upcoming-changes-to-ntlmv1-in-windows-11-version-24h2-and-windows-server-2025-c0554217-cdbc-420f-b47c-e02b2db49b2e>

Kerberos Delegation

- <https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-constrained-delegation-overview>
- <https://learn.microsoft.com/en-us/archive/blogs/poshchap/security-focus-analysing-account-is-sensitive-and-cannot-be-delegated-for-privileged-accounts>
- [https://learn.microsoft.com/en-us/previous-versions/tn-archive/cc995228\(v=technet.10\)?redirectedfrom=MSDN](https://learn.microsoft.com/en-us/previous-versions/tn-archive/cc995228(v=technet.10)?redirectedfrom=MSDN)
- <https://syfuhs.net/understanding-identity-delegation>

Kerberos Encryption

- <https://syfuhs.net/lessons-in-disabling-rc4-in-active-directory>
- <https://www.microsoft.com/en-us/windows-server/blog/2025/12/03/beyond-rc4-for-windows-authentication/>
- <https://support.microsoft.com/en-us/topic/how-to-manage-kerberos-kdc-usage-of-rc4-for-service-account-ticket-issuance-changes-related-to-cve-2026-20833-1ebcda33-720a-4da8-93c1-b0496e1910dc>

PLAN. IMPLEMENT. FAIL. START OVER

1. Start with MS Baselines
2. Sort by Impact vs. Risk
 - a. Does this affect the business?
 - b. What security gain do we get?
3. Move to STIGs or use CIS.

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 2 minutes

If you don't know where to start, start with MS Baselines. They're fast, their simple.

Regardless of where you start, review the settings and get a rough idea of compliance. If you're looking at STIGs or CIS Benchmarks they're categorized by severity. I recommend reviewing the missing configurations or items and splitting them into three groups: high-impact, moderate-impact, and low-impact. Impact here isn't security risk -- impact is how likely am I to cause an a resume generating event by doing this? I have a list in the slide notes that you can look at later where I make an attempt to do some of this categorization for you, so I encourage you to look at that. Just be careful, what I think is low impact may not be low impact in your environment.

Get projects started and approvals moving for the bigger items and start knocking out the low-impact items. They will move your bar forward and while the gains won't be great, they are a start. Once those start moving you can start focusing on the larger items.

Another thing I tend to do is compare the settings from a couple of the different benchmarks and choose the stricter of the two when they differ. This is particularly useful for audit settings as they vary a lot between the different baselines.

Don't get overwhelmed. From there work through the findings systematically. Anything you can implement easily without taking on too much business risk, do it. Everything else get plans and

projects in place to start resolving them over time. If your security team is pushing for things, that helps prioritize.

THE GHOST OF WEAK PASSWORDS

Password Controls

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

A few years ago NIST completely overhauled the guidance on passwords and password policies.

One the the challenges I noticed, most solutions to NIST's requirements involve a cost.



NIST SPECIAL PUBLICATION 800-63B

1. Password Length > Complexity
2. Bad Password Lists
 - a. (credential screening)
3. Passwordless = Win
4. Forced Expiration = Not Win

<https://pages.nist.gov/800-63-3/sp800-63b.html>

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

1. Password Length is better than password complexity.
2. Use bad password lists to prevent use of known compromised passwords.
3. Deploy passwordless solutions wherever possible.
4. Do not employ forced expiration of passwords at an interval. Only force resets on known compromised accounts.

While I don't 100% agree with all these, there is a lot of good information here. What could go wrong?

Resources and References:

- <https://pages.nist.gov/800-63-3/sp800-63b.html>

BAD PASSWORD LISTS

Microsoft has had them forever

Password Filters

<https://learn.microsoft.com/en-us/windows/win32/secmgmt/password-filters>

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 3 minutes

Bad Password lists (also called Password Filters in AD) have been in AD for a long time. They pre-date Azure.

Based on how the filter's design they can just be simple keyword matches, there are also wildcards, and all kinds of options built into them. They're pretty slick.

All the different filter types behave more or less the same. You can have lists of known bad passwords (haveibeenpwned) and you can create certain customization to match your needs.

Entra Password Protection is more or less the industry standard. Or at least that's what it is called today. I fully suspect in two weeks it will be called something like Defender Copilot for Password or some absolute nonsense.

EPP is great. It is easy to setup and does pretty much what you want it to do. It does require P1 or P2 licenses, or one of the Es but beyond that it is just a proxy server that lives on prem that syncs the password lists from the cloud. AD checks the proxy and you get filtering.

Moving away from a first party option is Lithnet, a company out of Australia that I'm in no way affiliated with. They have some kickass free tools.

Lithent Password Protection is free. And Open Source. It's less glamorous than EPP but it works.

Install it. Run a command to add HavelBeenPwed and your set.

I'll mention them more later.

This last one is our honorable mention. It is a password filter written by Ryan Ries who is a legend at Microsoft. He wrote this tool ages ago, it works. I should be clear it is NOT an official Microsoft product. He even did some major updates a couple years ago. It's even less polished than Lithnet.

Resources and References

- <https://learn.microsoft.com/en-us/windows/win32/secmgmt/password-filters>

- <https://learn.microsoft.com/en-us/entra/identity/authentication/concept-password-ban-bad>

- <https://github.com/lithnet/ad-password-protection>

- github.com/ryanries/PassFiltEx

BAD PASSWORD LISTS

Microsoft has had them forever

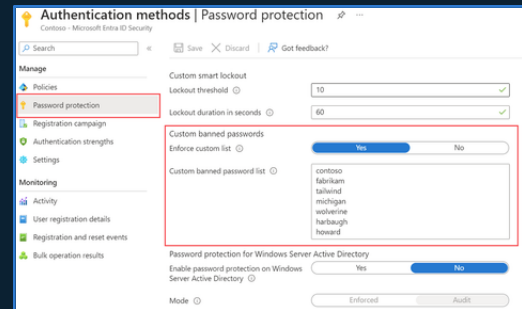
Password Filters

<https://learn.microsoft.com/en-us/windows/win32/secgmt/password-filters>

Entra Password Protection (EPP)

- Cloud Solution + Not Free
- Formerly Azure Password Protection (APP)

<https://learn.microsoft.com/en-us/entra/identity/authentication/concept-password-ban-bad>



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 3 minutes

Bad Password lists (also called Password Filters in AD) have been in AD for a long time. They pre-date Azure.

Based on how the filter's design they can just be simple keyword matches, there are also wildcards, and all kinds of options built into them. They're pretty slick.

All the different filter types behave more or less the same. You can have lists of known bad passwords (haveibeenpwned) and you can create certain customization to match your needs.

Entra Password Protection is more or less the industry standard. Or at least that's what it is called today. I fully suspect in two weeks it will be called something like Defender Copilot for Password or some absolute nonsense.

EPP is great. It is easy to setup and does pretty much what you want it to do. It does require P1 or P2 licenses, or one of the Es but beyond that it is just a proxy server that lives on prem that syncs the password lists from the cloud. AD checks the proxy and you get filtering.

Moving away from a first party option is Lithnet, a company out of Australia that I'm in no way affiliated with. They have some kickass free tools.

Lithent Password Protection is free. And Open Source. It's less glamorous than EPP but it works.

Install it. Run a command to add HavelBeenPwed and your set.

I'll mention them more later.

This last one is our honorable mention. It is a password filter written by Ryan Ries who is a legend at Microsoft. He wrote this tool ages ago, it works. I should be clear it is NOT an official Microsoft product. He even did some major updates a couple years ago. It's even less polished than Lithnet.

Resources and References

- <https://learn.microsoft.com/en-us/windows/win32/secmgmt/password-filters>

- <https://learn.microsoft.com/en-us/entra/identity/authentication/concept-password-ban-bad>

- <https://github.com/lithnet/ad-password-protection>

- github.com/ryanries/PassFiltEx

BAD PASSWORD LISTS

Microsoft has had them forever

Password Filters

<https://learn.microsoft.com/en-us/windows/win32/secgmt/password-filters>

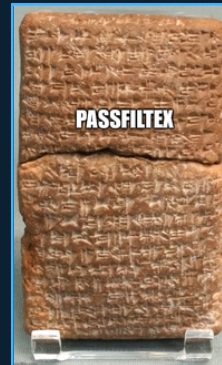
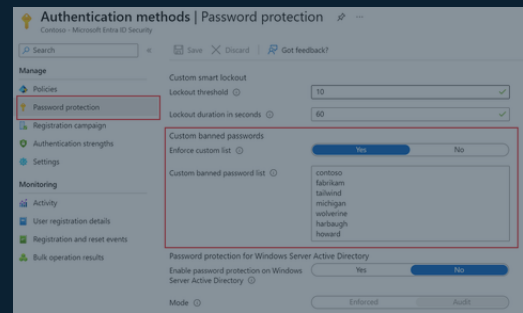
Entra Password Protection (EPP)

- Cloud Solution + Not Free
- Formerly Azure Password Protection (APP)

<https://learn.microsoft.com/en-us/entra/identity/authentication/concept-password-ban-bad>

Open Source / Freemium

- Lithnet Password Protection (freemium)
 - <https://github.com/lithnet/ad-password-protection>
- PassFiltEx (FOSS + Expertise)
 - github.com/ryanries/PassFiltEx



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 3 minutes

Bad Password lists (also called Password Filters in AD) have been in AD for a long time. They pre-date Azure.

Based on how the filter's design they can just be simple keyword matches, there are also wildcards, and all kinds of options built into them. They're pretty slick.

All the different filter types behave more or less the same. You can have lists of known bad passwords (haveibeenpwned) and you can create certain customization to match your needs.

Entra Password Protection is more or less the industry standard. Or at least that's what it is called today. I fully suspect in two weeks it will be called something like Defender Copilot for Password or some absolute nonsense.

EPP is great. It is easy to setup and does pretty much what you want it to do. It does require P1 or P2 licenses, or one of the Es but beyond that it is just a proxy server that lives on prem that syncs the password lists from the cloud. AD checks the proxy and you get filtering.

Moving away from a first party option is Lithnet, a company out of Australia that I'm in no way affiliated with. They have some kickass free tools.

Lithnet Password Protection is free. And Open Source. It's less glamorous than EPP but it works.

Install it. Run a command to add HavelBeenPwed and your set.

I'll mention them more later.

This last one is our honorable mention. It is a password filter written by Ryan Ries who is a legend at Microsoft. He wrote this tool ages ago, it works. I should be clear it is NOT an official Microsoft product. He even did some major updates a couple years ago. It's even less polished than Lithnet.

Resources and References

- <https://learn.microsoft.com/en-us/windows/win32/secmgmt/password-filters>

- <https://learn.microsoft.com/en-us/entra/identity/authentication/concept-password-ban-bad>

- <https://github.com/lithnet/ad-password-protection>

- github.com/ryanries/PassFiltEx



FACT

Many on-prem MFA solutions are theatre.

MFA / PASSKEYS

- MFA is great
- Passkeys are great (Not on-prem)
- SmartCard are great (Requires PKI)

OPTIONS?

- Duo Free Tier – 5 Accounts
- Entra MFA for Cloud*
- Cert-based Auth
 - Smart Cards + PKI
- Windows Hello for Business

Slide Time: 1 min

MFA in many of its on-prem implementations is really security theatre.

AD doesn't have any native MFA options on-prem. You have to go with a third party and they usually either function one of two ways.

1. They just secure RDP which, I'm sure all the Pentesters in the room will tell me is 100% the only way to breach an environment.
2. They require kernel-level process hooks which introduces some severe instability to Windows so you introduce operation risk.

Auditors like their tools and insurance has to check boxes so we may have to have something.

- Duo supports some trial accounts with limited features. This only protects the front door (RDP) and leaves other areas exposed.
- Entra MFA (for cloud solutions) since super privilege accounts shouldn't be synced, this is limited. There are some options in my notes.
- Cert-based Auth. This is MFA without the traditional push notification and "enter the number". This is just certificate-based auth. Problem here is the PKI side of it, hardware tokens, and

auditors don't get it so they may flag it.

SPEEDY PASSWORD HARDENING

- Do – Use Fine-Grained Password Policies



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

- Fine Grained Password Policies Don't cost anything. They can be deployed to add a more (or less) restrictive password and lockout policy to any user or group. Keep an eye on the Precedence, smaller the number the more priority it has.
- Complexity - If you have a sufficiently long password and are encouraging pass phrases, get rid of Complexity. I leave it on in a FGPP for super-admins (Domain Admins, etc.).
- Password Length: 16 characters or bust. 21 for privileged accounts and 32 for service accounts.
- Password Safes - If you aren't using one, do it. You've probably heard this before, but seriously use something. If you're company doesn't recommend one, get on that.
- Lockout Policy - 3-5 bad passwords before lockout is the standard. Which is insane and will generate help desk tickets. If you can, I encourage you to use the 15 rule.
 - 15 tries in 15 minutes gets locked for 15 minutes.

Scale the first 15 to 25 or 50 if you want to really loosen up.

- Deploy and configure a Password Filtering solution. Any of the ones I listed will get it done.
- Password Expiration - For NON PRIVILEGED ACCOUNTS, get rid of it. For Privileged Users

(all) set it to 180 or 365. Make sure you have a break-glass or two (that's monitored).

I personally think about a yearly graceful reset of all accounts, especially privileged is a good idea but go with your gut on this. Don't cause an outage because your SQL Service Account expired.

SPEEDY PASSWORD HARDENING

- Do – Use Fine-Grained Password Policies
- Do – Turn off Password Complexity



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

- Fine Grained Password Policies Don't cost anything. They can be deployed to add a more (or less) restrictive password and lockout policy to any user or group. Keep an eye on the Precedence, smaller the number the more priority it has.
- Complexity - If you have a sufficiently long password and are encouraging pass phrases, get rid of Complexity. I leave it on in a FGPP for super-admins (Domain Admins, etc.).
- Password Length: 16 characters or bust. 21 for privileged accounts and 32 for service accounts.
- Password Safes - If you aren't using one, do it. You've probably heard this before, but seriously use something. If you're company doesn't recommend one, get on that.
- Lockout Policy - 3-5 bad passwords before lockout is the standard. Which is insane and will generate help desk tickets. If you can, I encourage you to use the 15 rule.
 - 15 tries in 15 minutes gets locked for 15 minutes.

Scale the first 15 to 25 or 50 if you want to really loosen up.

- Deploy and configure a Password Filtering solution. Any of the ones I listed will get it done.
- Password Expiration - For NON PRIVILEGED ACCOUNTS, get rid of it. For Privileged Users

(all) set it to 180 or 365. Make sure you have a break-glass or two (that's monitored).

I personally think about a yearly graceful reset of all accounts, especially privileged is a good idea but go with your gut on this. Don't cause an outage because your SQL Service Account expired.

SPEEDY PASSWORD HARDENING

- Do – Use Fine-Grained Password Policies
- Do – Turn off Password Complexity
- Do – Use 16+ Character Passwords



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

- Fine Grained Password Policies Don't cost anything. They can be deployed to add a more (or less) restrictive password and lockout policy to any user or group. Keep an eye on the Precedence, smaller the number the more priority it has.

- Complexity - If you have a sufficiently long password and are encouraging pass phrases, get rid of Complexity. I leave it on in a FGPP for super-admins (Domain Admins, etc.).

- Password Length: 16 characters or bust. 21 for privileged accounts and 32 for service accounts.

- Password Safes - If you aren't using one, do it. You've probably heard this before, but seriously use something. If you're company doesn't recommend one, get on that.

- Lockout Policy - 3-5 bad passwords before lockout is the standard. Which is insane and will generate help desk tickets. If you can, I encourage you to use the 15 rule.

- 15 tries in 15 minutes gets locked for 15 minutes.

Scale the first 15 to 25 or 50 if you want to really loosen up.

- Deploy and configure a Password Filtering solution. Any of the ones I listed will get it done.

- Password Expiration - For NON PRIVILEGED ACCOUNTS, get rid of it. For Privileged Users

(all) set it to 180 or 365. Make sure you have a break-glass or two (that's monitored).

I personally think about a yearly graceful reset of all accounts, especially privileged is a good idea but go with your gut on this. Don't cause an outage because your SQL Service Account expired.

SPEEDY PASSWORD HARDENING

- Do – Use Fine-Grained Password Policies
- Do – Turn off Password Complexity
- Do – Use 16+ Character Passwords
- Do – Use Password Safes (not picky)



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

- Fine Grained Password Policies Don't cost anything. They can be deployed to add a more (or less) restrictive password and lockout policy to any user or group. Keep an eye on the Precedence, smaller the number the more priority it has.

- Complexity - If you have a sufficiently long password and are encouraging pass phrases, get rid of Complexity. I leave it on in a FGPP for super-admins (Domain Admins, etc.).

- Password Length: 16 characters or bust. 21 for privileged accounts and 32 for service accounts.

- Password Safes - If you aren't using one, do it. You've probably heard this before, but seriously use something. If you're company doesn't recommend one, get on that.

- Lockout Policy - 3-5 bad passwords before lockout is the standard. Which is insane and will generate help desk tickets. If you can, I encourage you to use the 15 rule.

- 15 tries in 15 minutes gets locked for 15 minutes.

Scale the first 15 to 25 or 50 if you want to really loosen up.

- Deploy and configure a Password Filtering solution. Any of the ones I listed will get it done.

- Password Expiration - For NON PRIVILEGED ACCOUNTS, get rid of it. For Privileged Users

(all) set it to 180 or 365. Make sure you have a break-glass or two (that's monitored).

I personally think about a yearly graceful reset of all accounts, especially privileged is a good idea but go with your gut on this. Don't cause an outage because your SQL Service Account expired.

SPEEDY PASSWORD HARDENING

- Do – Use Fine-Grained Password Policies
- Do – Turn off Password Complexity
- Do – Use 16+ Character Passwords
- Do – Use Password Safes (not picky)
- Do – Change your lockout policy
 - 15 Rule



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

- Fine Grained Password Policies Don't cost anything. They can be deployed to add a more (or less) restrictive password and lockout policy to any user or group. Keep an eye on the Precedence, smaller the number the more priority it has.

- Complexity - If you have a sufficiently long password and are encouraging pass phrases, get rid of Complexity. I leave it on in a FGPP for super-admins (Domain Admins, etc.).

- Password Length: 16 characters or bust. 21 for privileged accounts and 32 for service accounts.

- Password Safes - If you aren't using one, do it. You've probably heard this before, but seriously use something. If you're company doesn't recommend one, get on that.

- Lockout Policy - 3-5 bad passwords before lockout is the standard. Which is insane and will generate help desk tickets. If you can, I encourage you to use the 15 rule.

- 15 tries in 15 minutes gets locked for 15 minutes.

Scale the first 15 to 25 or 50 if you want to really loosen up.

- Deploy and configure a Password Filtering solution. Any of the ones I listed will get it done.

- Password Expiration - For NON PRIVILEGED ACCOUNTS, get rid of it. For Privileged Users

(all) set it to 180 or 365. Make sure you have a break-glass or two (that's monitored).

I personally think about a yearly graceful reset of all accounts, especially privileged is a good idea but go with your gut on this. Don't cause an outage because your SQL Service Account expired.

SPEEDY PASSWORD HARDENING

- Do – Use Fine-Grained Password Policies
- Do – Turn off Password Complexity
- Do – Use 16+ Character Passwords
- Do – Use Password Safes (not picky)
- Do – Change your lockout policy
 - 15 Rule
- Do – Deploy a Password Filter Solution



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

- Fine Grained Password Policies Don't cost anything. They can be deployed to add a more (or less) restrictive password and lockout policy to any user or group. Keep an eye on the Precedence, smaller the number the more priority it has.

- Complexity - If you have a sufficiently long password and are encouraging pass phrases, get rid of Complexity. I leave it on in a FGPP for super-admins (Domain Admins, etc.).

- Password Length: 16 characters or bust. 21 for privileged accounts and 32 for service accounts.

- Password Safes - If you aren't using one, do it. You've probably heard this before, but seriously use something. If you're company doesn't recommend one, get on that.

- Lockout Policy - 3-5 bad passwords before lockout is the standard. Which is insane and will generate help desk tickets. If you can, I encourage you to use the 15 rule.

- 15 tries in 15 minutes gets locked for 15 minutes.

Scale the first 15 to 25 or 50 if you want to really loosen up.

- Deploy and configure a Password Filtering solution. Any of the ones I listed will get it done.

- Password Expiration - For NON PRIVILEGED ACCOUNTS, get rid of it. For Privileged Users

(all) set it to 180 or 365. Make sure you have a break-glass or two (that's monitored).

I personally think about a yearly graceful reset of all accounts, especially privileged is a good idea but go with your gut on this. Don't cause an outage because your SQL Service Account expired.

SPEEDY PASSWORD HARDENING

- Do – Use Fine-Grained Password Policies
- Do – Turn off Password Complexity
- Do – Use 16+ Character Passwords
- Do – Use Password Safes (not picky)
- Do – Change your lockout policy
 - 15 Rule
- Do – Deploy a Password Filter Solution
- Do – Use MFA (dispel the auditors)



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

- Fine Grained Password Policies Don't cost anything. They can be deployed to add a more (or less) restrictive password and lockout policy to any user or group. Keep an eye on the Precedence, smaller the number the more priority it has.

- Complexity - If you have a sufficiently long password and are encouraging pass phrases, get rid of Complexity. I leave it on in a FGPP for super-admins (Domain Admins, etc.).

- Password Length: 16 characters or bust. 21 for privileged accounts and 32 for service accounts.

- Password Safes - If you aren't using one, do it. You've probably heard this before, but seriously use something. If you're company doesn't recommend one, get on that.

- Lockout Policy - 3-5 bad passwords before lockout is the standard. Which is insane and will generate help desk tickets. If you can, I encourage you to use the 15 rule.

- 15 tries in 15 minutes gets locked for 15 minutes.

Scale the first 15 to 25 or 50 if you want to really loosen up.

- Deploy and configure a Password Filtering solution. Any of the ones I listed will get it done.

- Password Expiration - For NON PRIVILEGED ACCOUNTS, get rid of it. For Privileged Users

(all) set it to 180 or 365. Make sure you have a break-glass or two (that's monitored).

I personally think about a yearly graceful reset of all accounts, especially privileged is a good idea but go with your gut on this. Don't cause an outage because your SQL Service Account expired.

SPEEDY PASSWORD HARDENING

- Do – Use Fine-Grained Password Policies
- Do – Turn off Password Complexity
- Do – Use 16+ Character Passwords
- Do – Use Password Safes (not picky)
- Do – Change your lockout policy
 - 15 Rule
- Do – Deploy a Password Filter Solution
- Do – Use MFA (dispel the auditors)
- Do – Look into Passwordless
 - (WH/WHfB)



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

- Fine Grained Password Policies Don't cost anything. They can be deployed to add a more (or less) restrictive password and lockout policy to any user or group. Keep an eye on the Precedence, smaller the number the more priority it has.

- Complexity - If you have a sufficiently long password and are encouraging pass phrases, get rid of Complexity. I leave it on in a FGPP for super-admins (Domain Admins, etc.).

- Password Length: 16 characters or bust. 21 for privileged accounts and 32 for service accounts.

- Password Safes - If you aren't using one, do it. You've probably heard this before, but seriously use something. If you're company doesn't recommend one, get on that.

- Lockout Policy - 3-5 bad passwords before lockout is the standard. Which is insane and will generate help desk tickets. If you can, I encourage you to use the 15 rule.

- 15 tries in 15 minutes gets locked for 15 minutes.

Scale the first 15 to 25 or 50 if you want to really loosen up.

- Deploy and configure a Password Filtering solution. Any of the ones I listed will get it done.

- Password Expiration - For NON PRIVILEGED ACCOUNTS, get rid of it. For Privileged Users

(all) set it to 180 or 365. Make sure you have a break-glass or two (that's monitored).

I personally think about a yearly graceful reset of all accounts, especially privileged is a good idea but go with your gut on this. Don't cause an outage because your SQL Service Account expired.

SPEEDY PASSWORD HARDENING

- Do – Use Fine-Grained Password Policies
- Do – Turn off Password Complexity
- Do – Use 16+ Character Passwords
- Do – Use Password Safes (not picky)
- Do – Change your lockout policy
 - 15 Rule
- Do – Deploy a Password Filter Solution
- Do – Use MFA (dispel the auditors)
- Do – Look into Passwordless
 - (WH/WHfB)
- DO NOT – Force Password Expiration



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

- Fine Grained Password Policies Don't cost anything. They can be deployed to add a more (or less) restrictive password and lockout policy to any user or group. Keep an eye on the Precedence, smaller the number the more priority it has.

- Complexity - If you have a sufficiently long password and are encouraging pass phrases, get rid of Complexity. I leave it on in a FGPP for super-admins (Domain Admins, etc.).

- Password Length: 16 characters or bust. 21 for privileged accounts and 32 for service accounts.

- Password Safes - If you aren't using one, do it. You've probably heard this before, but seriously use something. If you're company doesn't recommend one, get on that.

- Lockout Policy - 3-5 bad passwords before lockout is the standard. Which is insane and will generate help desk tickets. If you can, I encourage you to use the 15 rule.

- 15 tries in 15 minutes gets locked for 15 minutes.

Scale the first 15 to 25 or 50 if you want to really loosen up.

- Deploy and configure a Password Filtering solution. Any of the ones I listed will get it done.

- Password Expiration - For NON PRIVILEGED ACCOUNTS, get rid of it. For Privileged Users

(all) set it to 180 or 365. Make sure you have a break-glass or two (that's monitored).

I personally think about a yearly graceful reset of all accounts, especially privileged is a good idea but go with your gut on this. Don't cause an outage because your SQL Service Account expired.

THE GHOST OF INCOMPLETE ACCESS CONTROLS

Hardening Accounts & Access

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Section: 11 min

Slide: 1 min

This is where I would normally go on and on about tiering or the Enterprise Access Model for the cloud hipsters in the room.

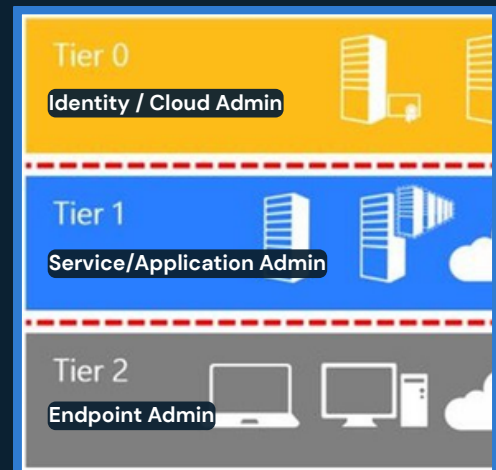
Shifting away from those we'll focus on items that don't involve as big of projects that find some actionable targets.

WHY I'M NOT TALKING A LOT ABOUT TIERING

- Tiering = Good
- Everyone talks about it
- No one finishes it
- Environments still vulnerable.

MY ADVICE ON TIERING

- Tier 0 First
 - Domain/Identity Level Administrator Rights
 - Environment-wide Administrative Rights
- Isolate and Secure Tier 0 Users
- Isolate and Secure Tier 0 Systems
- Identify Tier 0 Dependencies



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide: 2 min

I like tiering, I do, but it is well covered. Also, organizations tend to get started and never finishing leaving this dumpster fire of access with no path forward. Without a complete version, there are tons of hidden vulnerabilities and a false sense of security.

A quick guide to getting started with tiering:

1. Tier 0 should be hardened first. This is your domain admins, enterprise admins, global admins, and PKI admins and the like.
2. Isolate the users who are Tier 0. Give them separate accounts and secure those accounts.
3. Isolate system that are Tier 0 from being managed the same as all the others.
4. Find the dependencies. What tools run as system on the Tier 0 systems? Do they need that access? Can they be moved/built in the tier instead?

AUDIT ACCESS AND ACLS

Most organizations have no idea how bad it is.

Places to Start

- Domain Root
- Domain Controllers
- Privileged Users OUs
- Service Accounts OUs
- Executive Users OUs
- AdminSDHolder
Domain Root \ System \ AdminSDHolder

Permissions to Consider

- Full Control (Generic All)
- Control Access (CA)
- Owner / Change Owner
- Reset Password

Helpful Tools

THESE MAY TRIP EDR/AV

- ADDelegator
- AD ACL Scanner
- MS Adv. Audit Policies

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 2 minutes

Most organizations do not have an idea of how bad their access is. Many don't even know where to look. 10, 15, or 20 years of AD can lead to a lot of skeletons in the closet.

Start with looking at stuff that bad stuff tends to happen I put a list on screen. I'm not going to read it, but those are places whose ACLs need attention.

But what access is concerning?

Without being too detailed, focus on Full Control (Generic All), Control Access (CA), and Ownership permissions along with Reset Password.

There are more permissions and locations. I have some of it in my notes in the deck.

There are some tools that really help with this. My favorite of the list is probably ADDelegator which is a tool that specifically finds bad settings as they relate to known attacks. AD ACL scan is good as it gives a general overview. There are other tools out there too. Find what works for you and use it. Be warned, they may trip your EDR.

-- BONUS --

Some other permissions to consider are the following permissions.

- Replicate Changes

- Replicate Changes All
- Create permissions
- Delete Permissions
- WriteProperty to userAccountControl

All those are permissions that could expose critical information or allow for greater compromise.

Another tool worth mentioning is the Adalanche tool. It's really powerful but it is almost guaranteed to trip EDR.

SERVICE ACCOUNT HARDENING

What is a service account?

- Any account that runs a service OR has a SPN
- SPN = Service Principal Name
 - Method Kerberos uses to find services

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 2min

Service Accounts or in the age of clanker agents pretending to be people, I'm supposed to use the term "non-human identities", but I actually am talking about service accounts.

My definition is any account that either runs a service (Log on as Service / Se???) or any account with a servicePrincipalName (SPN) (pronounced Spin)

Loot I'm not here to teach you kerberos... I'd like to but I only have so much time. Check my slides for a quick primer on Kerberos. To keep time, ServicePrincipalNames are how services identify themselves on the network. They consist of a protocol, an address, and a port (e.g.; MSSQL\MyD BServer01\$:1633).

There are a number of attacks that bad service accounts can cause, and, again, I can't list them all here. Most often these attacks derive from either credential harvesting, bad passwords, or lack of access controls.

Service accounts run services and pretty quick become the backbone of the network. SQL is the one I always go on because I think most everyone has at least one story of SQL going down and it being a bad day.

With Service Accounts being instantly critical to the enterprise that means excuses and exceptions pop up and you get accounts who haven't had their password reset in 25 years.

25

years ago things were different. Security was a little different than it is today.

On top of that, since it is critical there is a good chance the service account has "Password Never Expires" set on it. Which isn't a bad thing. The bad part is there was never an administrative control to come back, audit those, and ensure they get manually reset in a controlled fashion.

This is amplified by the fact that service accounts, but nature are privileged accounts. They tend to be able to do stuff that we wouldn't just want rank-and-file users to do. So now we have a old password, on a privileged account.

find any account whose password hasn't been reset in over a year. Coordinate with those teams and reset the passwords.

When you identify something is truly a service account, mark it as such so this becomes easier later.

- There is an attribute in AD called flags that isn't used. It is an integer, so treat it like an enum and make every service account increment that field by +8192.
- Another field is attribute is employeeType. This one is a string. Just put Service Account in there.
- If those are used, you'll have to get creative.

Next, find any account that ISN'T a computer or a known service account that has a servicePrincipalName and either make it a service account or get it a dedicated service account to run that service. Then go in and block everyone but actual service accounts from Log on as Service.

```
`Get-ADUser -LDAPFilter "(servicePrincipalName=*)`
```

Alternatively if you did use the employee type...

```
`Get-ADUser -LDAPFilter "(&(servicePrincipalName=*)(employeeType=ServiceAccount))`
```

Cap it all off with the fact that a particular segment of attacks exploits vulnerable passwords to generate arbitrary kerberos authorizations (yep, authorizations) \ [Kerberoasting] and next thing you know that business critical service account has become a critical vulnerability.

-- REFERENCE

- <https://www.hipconf.com/resources/how-to-protect-machine-identities/>

SERVICE ACCOUNT HARDENING

What is a service account?

- Any account that runs a service OR has a SPN
- SPN = Service Principal Name
 - Method Kerberos uses to find services

What do we do?

- Replace old Service Account Passwords
- Audit + Remediate Account SPNs.
- Audit Access and Log On As Service Right
- Use MSAs

All reduce Kerberosting Risks

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 2min

Service Accounts or in the age of clanker agents pretending to be people, I'm supposed to use the term "non-human identities", but I actually am talking about service accounts.

My definition is any account that either runs a service (Log on as Service / Se???) or any account with a servicePrincipalName (SPN) (pronounced Spin)

Loot I'm not here to teach you kerberos... I'd like to but I only have so much time. Check my slides for a quick primer on Kerberos. To keep time, ServicePrincipalNames are how services identify themselves on the network. They consist of a protocol, an address, and a port (e.g.; MSSQL\MyD BServer01\$:1633).

There are a number of attacks that bad service accounts can cause, and, again, I can't list them all here. Most often these attacks derive from either credential harvesting, bad passwords, or lack of access controls.

Service accounts run services and pretty quick become the backbone of the network. SQL is the one I always go on because I think most everyone has at least one story of SQL going down and it being a bad day.

With Service Accounts being instantly critical to the enterprise that means excuses and exceptions pop up and you get accounts who haven't had their password reset in 25 years.

25

years ago things were different. Security was a little different than it is today.

On top of that, since it is critical there is a good chance the service account has "Password Never Expires" set on it. Which isn't a bad thing. The bad part is there was never an administrative control to come back, audit those, and ensure they get manually reset in a controlled fashion.

This is amplified by the fact that service accounts, but nature are privileged accounts. They tend to be able to do stuff that we wouldn't just want rank-and-file users to do. So now we have a old password, on a privileged account.

find any account whose password hasn't been reset in over a year. Coordinate with those teams and reset the passwords.

When you identify something is truly a service account, mark it as such so this becomes easier later.

- There is an attribute in AD called flags that isn't used. It is an integer, so treat it like an enum and make every service account increment that field by +8192.
- Another field is attribute is employeeType. This one is a string. Just put Service Account in there.
- If those are used, you'll have to get creative.

Next, find any account that ISN'T a computer or a known service account that has a servicePrincipalName and either make it a service account or get it a dedicated service account to run that service. Then go in and block everyone but actual service accounts from Log on as Service.

```
`Get-ADUser -LDAPFilter "(servicePrincipalName=*)`
```

Alternatively if you did use the employee type...

```
`Get-ADUser -LDAPFilter "(&(servicePrincipalName=*)(employeeType=ServiceAccount))`
```

Cap it all off with the fact that a particular segment of attacks exploits vulnerable passwords to generate arbitrary kerberos authorizations (yep, authorizations) \ [Kerberoasting] and next thing you know that business critical service account has become a critical vulnerability.

-- REFERENCE

- <https://www.hipconf.com/resources/how-to-protect-machine-identities/>

MANAGED SERVICE ACCOUNTS

- sMSAs = Standalone MSAs
 - Don't use
- gMSAs = Group Managed Service Accounts
 - Manage their own password + SPN
 - Non-Interactive
 - Multi-System
 - Harder to Kerberoast
 - Windows Only

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 3 min

I'm skipping right over standalone MSAs as they really aren't used. They're mostly gMSAs that only work on single systems and aren't nearly as useful so they don't get much love.

I hate the naming of these. Microsoft loves "Group" when it really already used that word.

The big features of gMSAs

- Self-Managed Passwords (No one even knows it)
- Self-SPN management.
- Not easily Kerberoastable (Can't be spoofed)
- Non-Interactive

These, as compared to the standalone MSAs, can be used on multiple systems. This is done through an attribute that effectively includes every system allowed to retrieve their password, which is stored and encrypted in some fun ways on the account.

You 100% should be using gMSAs. No excuses. They can be used on multiple computers, they manage their own passwords, they can be access controlled with groups, they manage their own SPNs (usually), and so on. They're awesome.

The biggest downsides to these is you have to make sure you control the setting that allows for retrieving the managed password and keep the riff-raff out, they do not work with other operating

systems (officially), and some apps want to have a physical password so they don't support gMSAs. This last one is surprising common considering how long gMSAs have been kicking around already.

They aren't perfect and they can still be abused, but they reduce the attack surface on those accounts significantly. I highly recommend using them wherever you can.

dMSAs = Delegated Managed Service Accounts

Okay, I want to mention these because they are straight up black magic and love it. These take gMSAs to a whole new level.

I'm not going to go super in depth on these as 1) I have only tested them in labs and 2) they're so new that really very few people are going to be looking at them yet. In my notes there is a link to a talk at HIP 2025 where an MVP goes into detail on all the MSA types that is straight gold.

dMSAs require Server 2025 and the new Server 2025 functional levels in Active Directory. Yes Microsoft is still putting effort into AD after all these years. We're not dead yet!

That is honestly their major downside. Well that and BadSuccessor which was a pretty gnarly vulnerability that came out for them like right after they were released. The vulnerability is improper access controls in AD so with proper access controls it is heavily mitigated.

The short version of them is that look and behave similar to gMSAs except they are linked to a traditional (full user) service account. Whenever that service account's password is authenticated on the network, AD intercepts that and does a validation of the machine identity and some other wizardry. If it passes, AD swaps the access using the dMSA behind the scenes and does the authentication. Effectively this gives the same effect of having a gMSA without the trouble of actually setting up on end systems.

I encourage you to keep an eye on dMSAs as much as you can and get comfortable with them.

-- REFERENCES

- <https://www.hipconf.com/resources/demystifying-managed-service-accounts-best-practices-security-measures-to-reduce-risk-and-impact/>

gMSA Reference

- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/group-managed-service-accounts/group-managed-service-accounts/group-managed-service-accounts-overview>

dMSA References

- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/delegated-managed-service-accounts/delegated-managed-service-accounts-overview>
- <https://jorgequestforknowledge.wordpress.com/2025/07/11/how-to-block-badsuccessor-the-good-bad-and-ugly-of-dmsa-migration/>
- <https://jorgequestforknowledge.wordpress.com/2025/09/02/from-badsuccessor-to-patchedsuccessor/>
- <https://jorgequestforknowledge.wordpress.com/2025/05/25/reviewing-your-delegation-model-before-introducing-w2k25-dcs-and-enhancing-security-due-to-badsuccessor/>

MANAGED SERVICE ACCOUNTS

- sMSAs = Standalone MSAs
 - Don't use
- gMSAs = Group Managed Service Accounts
 - Manage their own password + SPN
 - Non-Interactive
 - Multi-System
 - Harder to Kerberoast
 - Windows Only
- dMSAs = Delegated Managed Service Accounts
 - New in 2025
 - Link old Service Accounts with dMSA = gMSA for unsupported apps.
 - BadSuccessor = :(
 - Server 2025 = Kind of sketchy still

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 3 min

I'm skipping right over standalone MSAs as they really aren't used. They're mostly gMSAs that only work on single systems and aren't nearly as useful so they don't get much love.

I hate the naming of these. Microsoft loves "Group" when it really already used that word.

The big features of gMSAs

- Self-Managed Passwords (No one even knows it)
- Self-SPN management.
- Not easily Kerberoastable (Can't be spoofed)
- Non-Interactive

These, as compared to the standalone MSAs, can be used on multiple systems. This is done through an attribute that effectively includes every system allowed to retrieve their password, which is stored and encrypted in some fun ways on the account.

You 100% should be using gMSAs. No excuses. They can be used on multiple computers, they manage their own passwords, they can be access controlled with groups, they manage their own SPNs (usually), and so on. They're awesome.

The biggest downsides to these is you have to make sure you control the setting that allows for retrieving the managed password and keep the riff-raff out, they do not work with other operating

systems (officially), and some apps want to have a physical password so they don't support gMSAs. This last one is surprising common considering how long gMSAs have been kicking around already.

They aren't perfect and they can still be abused, but they reduce the attack surface on those accounts significantly. I highly recommend using them wherever you can.

dMSAs = Delegated Managed Service Accounts

Okay, I want to mention these because they are straight up black magic and love it. These take gMSAs to a whole new level.

I'm not going to go super in depth on these as 1) I have only tested them in labs and 2) they're so new that really very few people are going to be looking at them yet. In my notes there is a link to a talk at HIP 2025 where an MVP goes into detail on all the MSA types that is straight gold.

dMSAs require Server 2025 and the new Server 2025 functional levels in Active Directory. Yes Microsoft is still putting effort into AD after all these years. We're not dead yet!

That is honestly their major downside. Well that and BadSuccessor which was a pretty gnarly vulnerability that came out for them like right after they were released. The vulnerability is improper access controls in AD so with proper access controls it is heavily mitigated.

The short version of them is that look and behave similar to gMSAs except they are linked to a traditional (full user) service account. Whenever that service account's password is authenticated on the network, AD intercepts that and does a validation of the machine identity and some other wizardry. If it passes, AD swaps the access using the dMSA behind the scenes and does the authentication. Effectively this gives the same effect of having a gMSA without the trouble of actually setting up on end systems.

I encourage you to keep an eye on dMSAs as much as you can and get comfortable with them.

-- REFERENCES

- <https://www.hipconf.com/resources/demystifying-managed-service-accounts-best-practices-security-measures-to-reduce-risk-and-impact/>

gMSA Reference

- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/group-managed-service-accounts/group-managed-service-accounts/group-managed-service-accounts-overview>

dMSA References

- <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/delegated-managed-service-accounts/delegated-managed-service-accounts-overview>
- <https://jorgequestforknowledge.wordpress.com/2025/07/11/how-to-block-badsuccessor-the-good-bad-and-ugly-of-dmsa-migration/>
- <https://jorgequestforknowledge.wordpress.com/2025/09/02/from-badsuccessor-to-patchedsuccessor/>
- <https://jorgequestforknowledge.wordpress.com/2025/05/25/reviewing-your-delegation-model-before-introducing-w2k25-dcs-and-enhancing-security-due-to-badsuccessor/>



LOCAL ADMINISTRATOR ACCOUNT HARDENING

- LAPS = Local Administrator Password Solution
 - Legacy = Okay
 - Windows LAPS = Great! (W10/2016+)
 - Requires Schema Update (not scary)
 - ONLY the SID-500 Administrator
- Local Administrator Group Hardening
 - Remove Domain Admins and domain BUILTIN\Administrators from local admins
 - Remove users from Administrators wherever possible.
 - Hard but worth it.
- Lithnet RapidLAPS + Lithnet Access Manager
 - Freemium
 - Include some features not in Microsoft's offering

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 2 min

Okay, another show of hands.

- Who here has heard of LAPS, Local Administrator Password Solution?
- Who here has actually deployed it?
- Who here knows Microsoft overhauled it a couple years ago?

The problem LAPS solves is that organizations are lazy. Every local admin is created with the same local administrator password in provisioning and rarely are they disabled, even then they can be easily un-disabled as part of Windows Recovery.

LAPS used to be an installation that you had to download and install. Now it is *mostly* included with Windows. LAPS has an agent (transparent now) that coordinates with AD and stores the password in Active Directory for the local admin. AND ONLY THE LOCAL ADMIN (SID-500)

For this to work you do need to run a command to extend the AD Schema to include the LAPS attributes. This is required whether you use old LAPS or new LAPS but the attributes are different (there's a good reason, even I kind of hate it). It used to be stored plain-text and used access controls to secure it. With New LAPS it is better.

Another feature worth mentioning with New LAPS is it can be configured to auto-rotate the passwords when they are used rather than just on a schedule. This is a big deal. It's almost like Microsoft knows how to do PAM...

I have some notes and links in the slides that go into more. The short version of it is, if you're not using LAPS or a LAPS-like solution, you need to start doing that yesterday. It's not hard to manage.

Local Administrator Hardening - Local Admins

While we are on the topic of local admins here are a couple of things I am going to recommend to really move that security bar forward.

1. Remove domain admins, enterprise admins, and the domain builtin administrator account (and group) from all systems' local admins. You can do this with Group Policy. Create other administrative groups and restrict your super-privileged users from logging in everywhere. We'll talk more about this in a minute.
2. Remove any users you can from local admins. I know scrooge says that it allows him to have a smaller help desk, but day-to-day users don't need to be full time domain admins. Even if you're nuts and allowing them to look up the LAPS password to do stuff, it is better than them having sitting local admin.

Tools to Consider

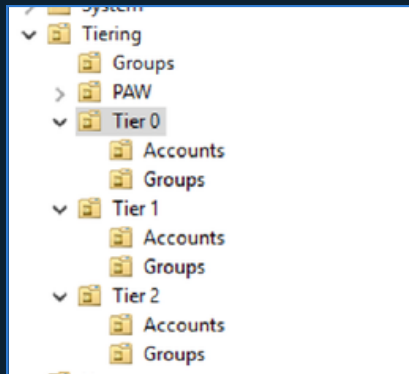
Lithnet came up once before in this talk and here they are again. They have a couple of products that I think are worth looking at.

Lithnet Access Manager has a free mode that is limited but for SMBs it may actually be enough. It can do some access delegations and is really helpful.

> MORE?

Lithnet RapidLAPS is their answer to old LAPS. It adds some features that Microsoft later added in new LAPS, but they also support an app that streamlines a lot of it. It is worth looking into.

GETTING STARTED WITH TIERING



- Dedicated Tier 0 / Control Plane Admins
 - No email. No Web. Just Admin stuff.
- Isolate Tier 0 Systems
 - Remove dependencies. Remove system and admin access not in Tier 0
- Deploy Secure Jump Hosts
 - Yes. Jump Hosts.
 - PAWs = Great + Massive Project
 - Start somewhere.
- TO Admins in Protected Users group
 - Lots of security. Some risk.
 - Roll out slowly.
 - No SID-500, Computers, or Services
- TO Password Policy
 - Complexity + Length + MFA (if possible)
 - Service Accounts too (no Protected Users)
 - 180 day password age

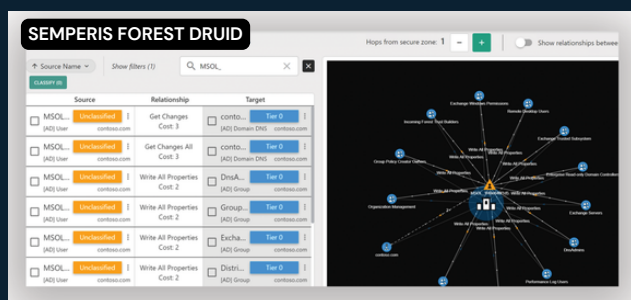
BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 1 min

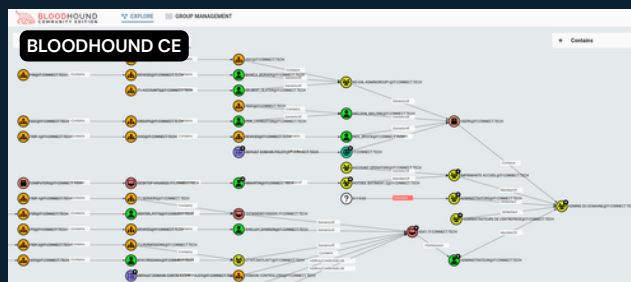
This is not a tiering talk so I'm limiting myself here some. Rather than overdoing it and spending three years failing at doing tiering, start with what can be done and then move onto the harder parts. I have more on this in my notes and in the bonus slides, but here are my top 5 tiering quick wins to keep this on track.

1. Tier 0 Admins / Control Plane Admins (Domain Admins, Global Admins, etc.) should be split off into separate accounts dedicated to tier 0. No email. No web browsing. Just super admin stuff.
2. Isolate your Tier 0 / Control Plane systems as much as you can. Reduce dependencies. Keep non-tier 0 admins off them and harden them.
3. Deploy Secure Jump Hosts. Yes, I said jump hosts. Yes, I love PAWs. PAWs are a big project. Jump hosts are training for that project and are better than RDPing to a DC from the system you browse the web from.
4. Tier 0 / Control Plane admins need to be members of Protected Users. This group does lots of hardening but can break stuff, especially old stuff. Roll this out slow over a week or two targeting one or two admins at a time. Don't put your break-glass or BuiltIn\Admin into this.
5. If you must have a Tier 0 service account(s), all the tier 0 hardening stuff applies minus Protected Users, MFA, and forced password expirations.



FINDING TIER 0

- Tier 0 Dependency and attack mapping
- Semperis Forest Druid
 - Free – Requires email.
 - Maps Tier 0 users, groups, etc.
 - Kind of clunky.
- SpectreOps Bloodhound CE
 - WILL TRIP EDR
 - The standard TO Attack Mapping Tool
 - CE = Community Edition = Free
 - Paid version available



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 2 min

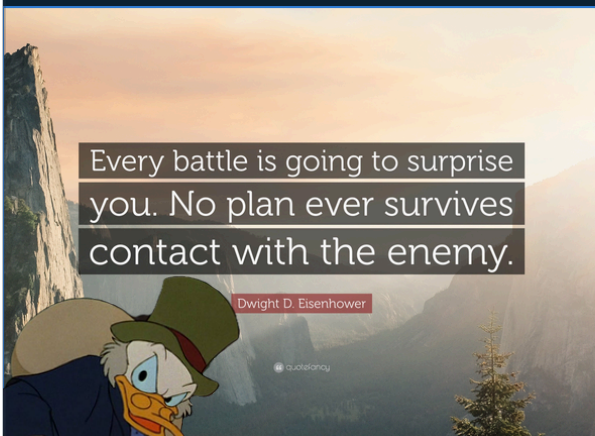
Here's a final recommendation to make some of it more approachable. I recommend looking at a tool like ForestDruid by Semperis or even Bloodhound Community Edition from SpectreOps to do some Tier 0 attack path mapping. This will help you identify your super admins in AD and start hardening them.

Note that BloodHound will 100% flag EDR so make sure you're working with your Security teams on this. The same applies to Forest Druid though I haven't seen it trip EDR yet.

Remember all of this is a start. This isn't intended to be comprehensive, but intended to get you meaningful wins that can actually get done while you're working on long-term solutions.

ACTION PLAN + IMPLEMENTATION

~~Dave Ramsey~~ Scrooge McDuck Approach



1. Backups – Get them now.
2. Baselines – Start with low impact
3. Harden Tier 0 Admins – Prot Users, Isolation, etc.
4. Reset Old Passwords – 365 days+
5. Harden Users with SPNs – Fix or harden.
6. Deploy LAPS
7. Audit Policies + Start ACL Audits

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 2 min

There is a Dave Ramsey... I mean Scrooge McDuck approach here that fits. Do what you can get done first. Make sure the items that need time are put in the approval change ASAP to move them .

1. Backups - Get backups running and stored somewhere. Work on resiliency and immutability of the backups later. Make sure they're secure from unwanted access though.
2. Security Baselines - Focus on Low Impact items and High Risk Items First. If it is going to take longer than a week or two to get implemented, get it on a project list. Do your Domain Controllers/TO first, then workstations, then servers.
3. Tier 0 Administrator Hardening - Harden the Tier 0 Admins. This should be a small group (hopefully) and won't have big impacts. This also means give them their own accounts.
4. Reset Old Passwords - Find users with passwords older than 365 days. Start working on getting them reset. This defies NIST some but at this point we're thinking these passwords aren't 16 characters.
5. Harden Users with Service Principal Names - Either remove the SPN and get them a service account or harden the heck out of that user. This may take some time but it is worth it.
6. Deploy LAPS - This really doesn't take long and you can enable per system via GPO so it can be phased in.
7. ACL Scans - Start checking for bad ACLs and fixing them. At a minimum know what you have.

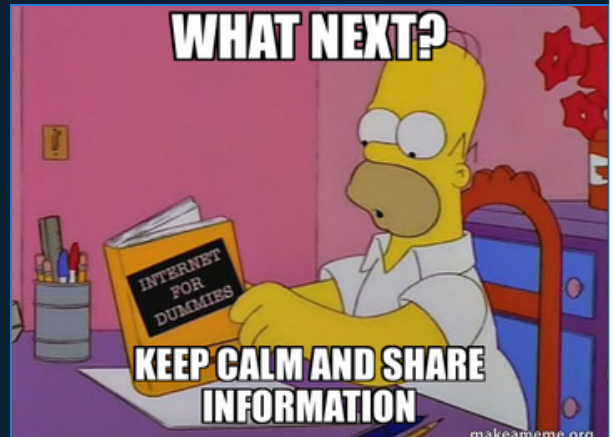
Most of those items are fairly low barriers to start. They may take a week or two to get running but

you will get wins.

NEXT STEPS

Action Plan Done. Now what?

- Run Purple Knight or Ping Castle + Do Fixes
- If running AD CS, run Locksmith.
- Automate SCAP Scans + Remediate.
- Review Backups + Improve.
- Bigger Projects
 - More Tiering
 - More Baseline Settings (Higher Impact)
 - PAWs Project
 - PAM Solutions (not Miser-friendly)
 - ...



BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 2 min

Once you've finished the items I've already talked about or have them rolling forward start thinking of where to go.

Next, look into tools like PurpleKnight or PingCastle to get a general AD health assessment. If you're running PKI using AD CS, make sure you run Locksmith it is pretty much the go-to PKI auditing tool.

Start looking at making sure your backups are perfect and reliable and immutable.

Move onto bigger and harder projects. Keep hammering at the baselines, look into a full AD/Cloud Tiering Project, and maybe start looking into PAM solutions (Not Scrooge Friendly).

Wrap Up

It's okay to feel overwhelmed. Pick one item and work it at a time.

Resources + Links

- Deck will be on Github soon
- r/ActiveDirectory Wiki
<https://www.reddit.com/r/ActiveDirectory/wiki>

Connect with Me

- Discord: @Poolmanjim
- Reddit: [u/Poolmanjim](https://www.reddit.com/u/Poolmanjim)
- LinkedIn: [linkedin.com/in/thetylerjacobs](https://www.linkedin.com/in/thetylerjacobs)
- Blog: activedirectorykc.net
- Github: github.com/activedirectorykc
- Email: **CLASSIFIED**
- I'll be over there - With some stickers



[HTTPS://LINKEDIN.COM/IN/THETYLERJACOBS](https://www.linkedin.com/in/thetylerjacobs)

QUESTIONS???



Do Some Good

- Change the world one day and one person at a time.
- Something that matters - Sign up to be a bone marrow donor.



[HTTPS://GITHUB.COM/ACTIVEDIRECTORYKC](https://github.com/activedirectorykc)

BSIDESKC 2026

TYLER JACOBS | POOLMANJIM

Slide Time: 2 min

I covered a lot. Its okay to feel overwhelmed. Take it one item at a time and move the security bar forward.

Lastly, resources. I broke the slide rule with lots of links, I'm sorry.

- The notes will be published later today on my Github. The QR code will take you to my Github.

- I have tons of bonus slides so they will cover way more than I covered here.

- Check out the r/ActiveDirectory subreddit, especially the wiki. There are tons of resources there. Share these resources far and wide, just attribute the work to the creators.

- Connect with me if you're interested. I'm on Discord until it isn't cool anymore, but you can find me on Reddit and LinkedIn. You can email me, but I suck at responding so good luck.

- Ask me about AD stuff, Identity, or PowerShell. Also I love chatting D&D and how I've been using LLMs to make me a better DM.

- Finally, I have your attention. Do something good for the world. If its little, it still matters. Something you can do that could really change at least one life is sign up to be a bone marrow donor. Hit me up if you have questions about any of that.

- OH. I have a few stickers so if you're into that sort of things, come find me over there after this is done if you want one.

God Bless!

(Slide)

QnA

The plan was to have a couple of minutes at least so hit me with any questions you have. I'll do my best or make something up. Regardless come find me if you want to chat any of this stuff, I love talking AD.